EduViet: Website bán khóa học trực tuyến

Tài liệu kỹ thuật

Sinh viên thực hiện: Phạm Hoàng Duy · MSSV 170125375 · Lớp DK25TTC5

Tạo ngày 09/11/2026 từ thesis/html/*.md

Mục lục

1. 01 — Phân tích yêu cầu & đặc tả nghiệp vụ
2. 02 — Kiến trúc hệ thống
3. 03 — Thiết kế cơ sở dữ liệu (SQL Server)
4. 04 — Chạy dự án trên máy tính
5. 05 — Design system
6. 06 — Backend API (Giai đoạn 2)
7. 07 — Frontend (Giai đoạn 3)
8. 08 — Học trực tuyến, kiểm tra và dashboard (Giai đoạn 4)
9. 09 — Thanh toán & lưu trữ tệp (Giai đoạn 5)
10. 10 — Chứng chỉ PDF & trang xác minh (Giai đoạn 6)
11. 11 — Triển khai lên môi trường thực tế
12. 12 — Báo cáo kiểm thử (Giai đoạn 7)
13. 13 — Design system giao diện
14. 14 — Điểm thưởng (Reward Points)

01 — Phân tích yêu cầu & đặc tả nghiệp vụ

Tên sản phẩm (tạm): **EduViet** — nền tảng bán và học khóa học trực tuyến.

1. Mục tiêu

Mục tiêu	Thước đo
Học viên tìm, mua và học khóa học trên mọi thiết bị	Mua được khóa học trong ≤ 3 bước từ trang chi tiết
Giảng viên tự xuất bản khóa học, có Admin kiểm duyệt	Quy trình Draft → Pending → Published/Rejected
Thanh toán an toàn, đối soát được	Quyền học chỉ cấp khi Backend xác thực chữ ký IPN
Chứng chỉ có thể xác minh công khai	Mỗi chứng chỉ có mã duy nhất, trang `/xac-minh/{code}`

2. Tác nhân (Actors)

Vai trò	Mô tả	Quyền chính
Guest	Khách chưa đăng nhập	Xem trang chủ, tìm kiếm, xem chi tiết khóa học, xem bài học preview, xác minh chứng chỉ, đăng ký, đăng nhập
Student	Học viên đã đăng ký	Giỏ hàng, đặt hàng, thanh toán, học, làm bài kiểm tra, nhận chứng chỉ, đánh giá khóa học đã mua
Instructor	Giảng viên (Admin cấp quyền hoặc duyệt đơn đăng ký giảng viên)	CRUD khóa học của mình, chương/bài học, tài liệu, quiz, xem học viên/doanh thu, trả lời đánh giá
Admin	Quản trị hệ thống	Toàn quyền: người dùng, danh mục, duyệt khóa học, đơn hàng, giao dịch, mã giảm giá, chứng chỉ, báo cáo

Một tài khoản có thể có nhiều vai trò (ví dụ Instructor cũng là Student). Tài khoản mới đăng ký luôn mang vai trò `Student`.

3. Danh sách chức năng (Functional Requirements)

Mã chức năng dùng xuyên suốt tài liệu, API và kiểm thử.

3.1 Trang chủ & khám phá (FR-HOME)

- FR-HOME-01 Banner giới thiệu, ô tìm kiếm.
- FR-HOME-02 Khóa học nổi bật (`IsFeatured`), mới nhất (`PublishedAt` desc), bán chạy (`EnrollmentCount` desc).
- FR-HOME-03 Danh mục khóa học (cây 2 cấp).
- FR-HOME-04 Giảng viên nổi bật (theo tổng học viên + điểm đánh giá).
- FR-HOME-05 Đánh giá tiêu biểu của học viên (rating ≥ 4, có nội dung).
- FR-HOME-06 Tìm kiếm + lọc: từ khóa, danh mục, cấp độ, khoảng giá, rating; sắp xếp; phân trang.

3.2 Tài khoản (FR-AUTH)

- FR-AUTH-01 Đăng ký (họ tên, email, mật khẩu) → vai trò Student, gửi email xác nhận.
- FR-AUTH-02 Đăng nhập trả về Access Token (JWT, 15 phút) + Refresh Token (7 ngày, HttpOnly cookie).
- FR-AUTH-03 Refresh token xoay vòng (rotation); phát hiện token cũ bị dùng lại → thu hồi toàn chuỗi.
- FR-AUTH-04 Đăng xuất = thu hồi refresh token.
- FR-AUTH-05 Quên mật khẩu → email chứa link đặt lại (token Identity, hết hạn 1 giờ).
- FR-AUTH-06 Cập nhật hồ sơ, ảnh đại diện; đổi mật khẩu (thu hồi mọi refresh token khác).
- FR-AUTH-07 Admin gán/bỏ vai trò, khóa/mở khóa tài khoản.

3.3 Khóa học (FR-COURSE)

- FR-COURSE-01 Instructor tạo/sửa/xóa mềm khóa học của mình (chỉ khi Draft hoặc Rejected được sửa nội dung chính).
- FR-COURSE-02 Ảnh đại diện, video giới thiệu (Cloudinary).
- FR-COURSE-03 Thuộc tính: danh mục, giá, giá khuyến mãi, cấp độ (Beginner/Intermediate/Advanced), mô tả, yêu cầu, kết quả đạt được.
- FR-COURSE-04 Chương (Section) và bài học (Lesson) có thứ tự, kéo thả sắp xếp.
- FR-COURSE-05 Bài học: video, bài viết; tài liệu đính kèm (PDF, ZIP…); cờ `IsPreview` , `IsRequired` .
- FR-COURSE-06 Trạng thái: `Draft → Pending` (gửi duyệt) → `Published` | `Rejected` (kèm lý do) → có thể sửa và gửi lại. Admin có thể `Unpublish` về `Draft` .
- FR-COURSE-07 Admin CRUD danh mục.

3.4 Mua khóa học (FR-ORDER)

- FR-ORDER-01 Xem chi tiết khóa học (đề cương, giảng viên, đánh giá).
- FR-ORDER-02 Giỏ hàng (thêm/xóa). Không thêm khóa đã sở hữu hoặc khóa của chính mình.
- FR-ORDER-03 Tạo đơn hàng từ giỏ hoặc "Mua ngay". **Giá lấy từ DB**, Frontend chỉ gửi danh sách `courseId` + mã giảm giá.
- FR-ORDER-04 Áp mã giảm giá (kiểm tra hiệu lực, giới hạn lượt, giá trị tối thiểu, phạm vi khóa học).
- FR-ORDER-05 Thanh toán VNPay Sandbox (chính) / MoMo Sandbox (phụ).
- FR-ORDER-06 Nhận IPN từ cổng → xác thực chữ ký + số tiền + trạng thái → idempotent → đơn `Paid` → tạo Enrollment.

- FR-ORDER-07 Trang Return chỉ **hiển thị** kết quả bằng cách hỏi Backend trạng thái đơn, không cấp quyền.
- FR-ORDER-08 Đơn tổng 0đ (mã giảm 100%) hoàn tất không qua cổng.
- FR-ORDER-09 Đơn `Pending` quá 30 phút tự hết hạn (`Expired`). Lượt mã giảm giá chỉ bị trừ khi đơn `Paid`, nên đơn hết hạn/hủy không tốn lượt.

3.5 Học trực tuyến (FR-LEARN)

- FR-LEARN-01 Trình học: danh sách chương/bài bên cạnh, video, nội dung, tài liệu.
- FR-LEARN-02 Link video/tài liệu trả phí là **signed URL** có hạn, chỉ cấp khi có Enrollment.
- FR-LEARN-03 Đánh dấu hoàn thành; lưu vị trí xem video (`LastPositionSeconds`).
- FR-LEARN-04 "Tiếp tục học" → bài gần nhất (`Enrollment.LastLessonId`).
- FR-LEARN-05 % hoàn thành = bài bắt buộc đã xong / tổng bài bắt buộc.

3.6 Kiểm tra (FR-QUIZ)

- FR-QUIZ-01 Instructor tạo quiz gắn với khóa học (tùy chọn gắn chương), đánh dấu bài thi cuối khóa.
- FR-QUIZ-02 Câu hỏi một đáp án / nhiều đáp án / đúng-sai, điểm từng câu.
- FR-QUIZ-03 Điểm đạt (%), số lần làm tối đa, thời gian giới hạn.
- FR-QUIZ-04 Backend chấm điểm; không gửi `IsCorrect` xuống client trước khi nộp.
- FR-QUIZ-05 Lưu lịch sử từng lần làm.

3.7 Chứng chỉ (FR-CERT)

- FR-CERT-01 Điều kiện: 100% bài bắt buộc + đạt mọi quiz `IsRequired`.
- FR-CERT-02 Tự cấp khi điều kiện thỏa (sau khi hoàn thành bài/nộp quiz); idempotent (1 chứng chỉ / học viên / khóa).
- FR-CERT-03 Mã định danh dạng `EDV-2026-7F3K9QX2` (unique), PDF sinh bằng QuestPDF có QR tới trang xác minh.
- FR-CERT-04 Trang xác minh công khai; Admin có thể thu hồi.

3.8 Dashboard

- Học viên: khóa đã mua, đang học, tiến độ, lịch sử thanh toán, kết quả kiểm tra, chứng chỉ, hồ sơ.
- Giảng viên: khóa học, nội dung, học viên, biểu đồ đăng ký & doanh thu theo tháng, đánh giá.
- Admin: tổng quan (doanh thu, học viên mới, khóa chờ duyệt), quản lý người dùng/khóa/danh mục/đơn/giao dịch/mã giảm giá/chứng chỉ, báo cáo.

4. Quy tắc nghiệp vụ (Business Rules)

Mã	Quy tắc
BR-01	Giá bán thực = `DiscountPrice` nếu có và < `Price`, ngược lại `Price`. Tiền tệ VND, làm tròn đến đồng.
BR-02	Không tạo đơn chứa khóa đã sở hữu, khóa chưa Published, hoặc khóa của chính người mua.
BR-03	Mỗi học viên chỉ có 1 Enrollment / khóa (unique index).
BR-04	Giá trong `OrderItems` là ảnh chụp tại thời điểm đặt (không đổi khi giảng viên đổi giá).
BR-05	Coupon: `Percentage` (0–100, có trần `MaxDiscountAmount`) hoặc `FixedAmount`; giảm không vượt tổng đơn.
BR-06	Một giao dịch cổng (`Provider` + `ProviderTransactionId`) chỉ được xử lý một lần.
BR-07	IPN hợp lệ khi: chữ ký đúng, `Amount` = `Order.TotalAmount`, đơn tồn tại và đang `Pending`.
BR-08	Chỉ khóa `Published` hiển thị công khai; khóa bị gỡ vẫn cho học viên đã mua tiếp tục học.
BR-09	Đánh giá: chỉ học viên có Enrollment, 1 đánh giá / khóa, rating 1–5.
BR-10	Quiz: lần làm thứ n bị từ chối nếu n > `MaxAttempts`; điểm tính theo điểm cao nhất.
BR-11	Xóa khóa học là xóa mềm (`IsDeleted`) nếu đã có Enrollment.
BR-12	Doanh thu giảng viên = tổng `OrderItems.FinalPrice` của khóa thuộc giảng viên, đơn `Paid`.

5. Yêu cầu phi chức năng

- **Bảo mật**: Identity (PBKDF2), JWT ký HMAC-SHA256 khóa ≥ 256 bit lấy từ biến môi trường/User Secrets, refresh token lưu **hash SHA-256**, rate limit đăng nhập & IPN, CORS giới hạn origin, HTTPS, header bảo mật, EF Core tham số hóa (chống SQL Injection), React tự escape + sanitize HTML bài viết bằng DOMPurify (chống XSS), FluentValidation cho mọi input.
- **Hiệu năng**: API danh sách có phân trang; index trên cột lọc/sắp xếp; `AsNoTracking` cho truy vấn đọc.
- **Khả dụng**: Responsive 360px → 1920px; giao diện tiếng Việt; trạng thái loading/empty/error.
- **Khả năng bảo trì**: Clean Architecture, DI, logging Serilog, Swagger.

6. Use Case Diagram

```
flowchart LR
  Guest([Guest])
  Student([Student])
  Instructor([Instructor])
  Admin([Admin])
  VNPay[[VNPay / MoMo]]

  subgraph System[EduViet]
    UC1(Xem & tìm kiếm khóa học)
```

```
    UC2(Đăng ký / Đăng nhập)
    UC3(Xác minh chứng chỉ)
    UC4(Quản lý giỏ hàng)
    UC5(Đặt hàng & áp mã giảm giá)
    UC6(Thanh toán)
    UC7(Học bài & lưu tiến độ)
    UC8(Làm bài kiểm tra)
    UC9(Nhận & tải chứng chỉ)
    UC10(Đánh giá khóa học)
    UC11(Quản lý khóa học / chương / bài)
    UC12(Tạo quiz & câu hỏi)
    UC13(Xem học viên & doanh thu)
    UC14(Duyệt khóa học)
    UC15(Quản lý người dùng & vai trò)
    UC16(Quản lý danh mục, mã giảm giá)
    UC17(Quản lý đơn hàng & giao dịch)
    UC18(Báo cáo thống kê)
  end

  Guest --> UC1 & UC2 & UC3
  Student --> UC1 & UC4 & UC5 & UC7 & UC8 & UC9 & UC10
  UC5 -. include .-> UC6
  UC6 --- VNPay
  Instructor --> UC11 & UC12 & UC13
  Admin --> UC14 & UC15 & UC16 & UC17 & UC18
  Student -. kế thừa .-> Guest
```

7. Luồng nghiệp vụ quan trọng

7.1 Thanh toán VNPay (cấp quyền chỉ qua IPN)

```
sequenceDiagram
  participant FE as React
  participant API as ASP.NET Core API
  participant DB as SQL Server
  participant VN as VNPay Sandbox

  FE->>API: POST /api/orders {courseIds, couponCode}
  API->>DB: Lấy giá từ Courses, kiểm tra sở hữu, coupon
  API->>DB: Tạo Order(Pending) + OrderItems + Payment(Pending, TxnRef)
  API-->>FE: {orderId}
  FE->>API: POST /api/payments/vnpay/{orderId}
  API-->>FE: paymentUrl (ký HMAC-SHA512)
  FE->>VN: Redirect người dùng
  VN->>API: GET /api/payments/vnpay/ipn (server-to-server)
  API->>API: Kiểm tra chữ ký, số tiền, trạng thái, idempotency
```

```
  API->>DB: Transaction: Payment=Success, Order=Paid, tạo Enrollments, tăng Coupon.UsedCount
  API-->>VN: {RspCode:"00"}
  VN-->>FE: Redirect /thanh-toan/ket-qua?...
  FE->>API: GET /api/orders/{id} (chỉ đọc trạng thái)
  API-->>FE: Paid → hiển thị "Vào học"
```

7.2 Vòng đời khóa học

```
stateDiagram-v2
  [*] --> Draft
  Draft --> Pending: Giảng viên gửi duyệt
  Pending --> Published: Admin duyệt
  Pending --> Rejected: Admin từ chối (lý do)
  Rejected --> Pending: Sửa & gửi lại
  Published --> Draft: Admin gỡ / GV ẩn
```

7.3 Cấp chứng chỉ

```
flowchart TD
  A[Hoàn thành bài học / Nộp quiz] --> B{100% bài bắt buộc?}
  B -- Không --> Z[Cập nhật tiến độ]
  B -- Có --> C{Đạt mọi quiz bắt buộc?}
  C -- Không --> Z
  C -- Có --> D{Đã có chứng chỉ?}
  D -- Có --> Z
  D -- Chưa --> E[Tạo Certificate + mã duy nhất]
  E --> F[Sinh PDF QuestPDF → Cloudinary]
  F --> G[Notification cho học viên]
```

02 — Kiến trúc hệ thống

1. Tổng quan

```
flowchart LR
  subgraph Client
    B[Trình duyệt<br/>React + TS + Vite]
  end
  subgraph Server[ASP.NET Core 10 Web API]
    API[OnlineLearning.API<br/>Controllers, Middleware, Auth]
    APP[OnlineLearning.Application<br/>Services, DTO, Validators, Interfaces]
    DOM[OnlineLearning.Domain<br/>Entities, Enums, Rules]
    INF[OnlineLearning.Infrastructure<br/>EF Core, Identity, VNPay, MoMo,<br/>Cloudinary, QuestPDF, Email]
  end
  DB[(SQL Server)]
  CLD[(Cloudinary)]
  PAY[[VNPay / MoMo Sandbox]]
  SMTP[[SMTP]]

  B -- HTTPS JSON + JWT --> API
  API --> APP --> DOM
  API --> INF
  INF --> APP
  INF --> DB
  INF --> CLD
  INF <--> PAY
  INF --> SMTP
```

2. Clean Architecture — quy tắc phụ thuộc

Project	Phụ thuộc	Chứa
`OnlineLearning.Domain`	(không, trừ `Microsoft.Extensions.Identity.Stores` cho `IdentityUser<Guid>`)	Entity, Enum, hằng số vai trò, quy tắc thuần
`OnlineLearning.Application`	Domain	Interface (`IAppDbContext`, `IPaymentGateway`, `IFileStorage`, `ICertificateGenerator`, `IEmailSender`, `ICurrentUser`), DTO,

Project	Phụ thuộc	Chứa
		service nghiệp vụ, FluentValidation, `Result<T>`
`OnlineLearning.Infrastructure`	Application, Domain	`AppDbContext`, cấu hình Fluent API, Migrations, seed, Identity, JWT, VNPay/MoMo, Cloudinary, QuestPDF, SMTP
`OnlineLearning.API`	Application, Infrastructure	Controllers, middleware lỗi, CORS, rate limiting, Swagger, `Program.cs`

Lõi nghiệp vụ (Domain + Application) không biết đến SQL Server, VNPay hay Cloudinary → đổi nhà cung cấp chỉ sửa Infrastructure.

3. Cấu trúc thư mục

```
(thư mục gốc repository)
├── setup/database/schema.sql     Script SQL Server tham chiếu (tương đương migration)
├── thesis/html/                  Tài liệu phân tích, thiết kế, hướng dẫn (các tệp 01–14 này)
├── docker/                       docker-compose.yml, .env.example
└── src/
    ├── backend/
    │   ├── OnlineLearning.sln
    │   └── src/
    │       ├── OnlineLearning.Domain/
    │       │   ├── Common/           BaseEntity, AuditableEntity
    │       │   ├── Constants/        Roles
    │       │   ├── Entities/         23 entity
    │       │   └── Enums/
    │       ├── OnlineLearning.Application/
    │       │   ├── Common/           Result, PagedResult, interfaces
    │       │   ├── Features/         Auth, Courses, Orders, Learning, Quizzes, Certificates, Admin…
    │       │   └── DependencyInjection.cs
    │       ├── OnlineLearning.Infrastructure/
    │       │   ├── Persistence/      AppDbContext, Configurations/, Migrations/, Seed/
    │       │   ├── Identity/         JwtTokenService
    │       │   ├── Payments/         VnPayGateway, MoMoGateway
    │       │   ├── Storage/          CloudinaryStorage
    │       │   ├── Certificates/     QuestPdfCertificateGenerator
    │       │   └── DependencyInjection.cs
    │       └── OnlineLearning.API/
    │           ├── Controllers/
    │           ├── Middleware/
    │           ├── Program.cs
    │           └── appsettings.json
```

```
└── frontend/
    └── online-learning-client/
        └── src/
            ├── assets/  components/  contexts/  hooks/
            ├── layouts/ pages/       services/  types/
            └── main.tsx, App.tsx, index.css
```

4. Bảo mật — quyết định kiến trúc

Mối nguy	Giải pháp
Lộ mật khẩu	ASP.NET Core Identity (PBKDF2 + salt), khóa tài khoản sau 5 lần sai
Đánh cắp token	Access token 15 phút trong bộ nhớ (không localStorage); refresh token HttpOnly + Secure + SameSite=Strict cookie, lưu **hash** trong DB, rotation + phát hiện tái sử dụng
Leo thang quyền	`[Authorize(Roles=…)]` + kiểm tra sở hữu tài nguyên trong service (Instructor chỉ sửa khóa của mình)
Sửa giá phía client	Backend tính lại giá từ DB; request chỉ chứa `courseIds`
Giả mạo callback	Xác thực HMAC-SHA512 (VNPay) / HMAC-SHA256 (MoMo), so khớp số tiền, chỉ IPN mới cấp quyền
Callback lặp	Unique index `(Provider, ProviderTransactionId)` + kiểm tra trạng thái trong transaction `Serializable`/rowversion
Truy cập video trả phí	Cloudinary `type=authenticated`, API cấp signed URL hết hạn sau 1 giờ khi có Enrollment
SQL Injection	Chỉ dùng EF Core LINQ (tham số hóa)
XSS	React escape mặc định; HTML bài viết lọc bằng DOMPurify; header CSP
Lộ bí mật	`appsettings.json` không chứa khóa thật; dùng User Secrets (dev) và biến môi trường (prod)
Brute force	`AddRateLimiter` cho `/auth/*` và `/payments/*`

5. Quy ước API

- Tiền tố `/api`, REST, JSON camelCase, phiên bản qua route khi cần (`/api/v1`).
- Phản hồi lỗi chuẩn `ProblemDetails` (RFC 7807) + danh sách lỗi validation.
- Phân trang: `?page=1&pageSize=12` → `{ items, page, pageSize, totalCount, totalPages }`.
- Thời gian lưu UTC (`datetime2`), Frontend hiển thị múi giờ `Asia/Ho_Chi_Minh`.

6. Frontend

Thư mục	Vai trò
`services/`	Axios instance + interceptor tự refresh token, mỗi module 1 file (`courseService.ts` ...)
`contexts/`	`AuthContext` (user, roles, accessToken), `CartContext`
`hooks/`	`useAuth` , `useDebounce` , `usePagination` ...
`layouts/`	`MainLayout` , `LearningLayout` , `DashboardLayout` (Student/Instructor/Admin)
`pages/`	Theo route, tiếng Việt slug: `/khoa-hoc/:slug` , `/gio-hang` , `/hoc/:courseId/:lessonId` ...
`components/`	UI dùng chung: `CourseCard` , `Button` , `EmptyState` , `Skeleton` , `ProtectedRoute`
`types/`	Kiểu TS khớp DTO Backend

Biểu đồ dashboard: Recharts. Thông báo: Sonner. HTML sanitize: DOMPurify.

03 — Thiết kế cơ sở dữ liệu (SQL Server)

- Code First bằng EF Core; script tham chiếu tương đương ở `setup/database/schema.sql`.
- Khóa chính `uniqueidentifier` (`NEWSEQUENTIALID()`) — không đoán được ID, không phân mảnh index.
- Tiền: `decimal(18,2)` (VND). Thời gian: `datetime2` UTC.
- Enum lưu dạng `nvarchar` (dễ đọc khi đối soát, không vỡ khi đổi thứ tự enum).
- Bảng Identity: `Users`, `Roles`, `UserRoles`, `UserClaims`, `UserLogins`, `UserTokens`, `RoleClaims` (đổi tên từ `AspNet*`).
- Xóa: cascade **chỉ trong cùng aggregate** (Course→Section→Lesson→Resource, Order→Item, Quiz→Question→Option…), còn lại `NO ACTION` để tránh multiple cascade paths của SQL Server.

1. ERD

```
erDiagram
  Users ||--o{ UserRoles : has
  Roles ||--o{ UserRoles : has
  Users ||--o{ RefreshTokens : owns
  Categories ||--o{ Categories : parent
  Categories ||--o{ Courses : groups
  Users ||--o{ Courses : teaches
  Courses ||--o{ CourseSections : contains
  CourseSections ||--o{ Lessons : contains
  Lessons ||--o{ LessonResources : attaches
  Users ||--o{ Enrollments : enrolls
  Courses ||--o{ Enrollments : has
  Enrollments ||--o{ LessonProgress : tracks
  Lessons ||--o{ LessonProgress : tracked
  Users ||--|| Carts : owns
  Carts ||--o{ CartItems : contains
  Courses ||--o{ CartItems : in
  Users ||--o{ Orders : places
  Coupons ||--o{ Orders : applied
  Orders ||--o{ OrderItems : contains
  Courses ||--o{ OrderItems : sold
  Orders ||--o{ Payments : paid_by
  Orders ||--o{ Enrollments : grants
  Courses ||--o{ Quizzes : has
  CourseSections ||--o{ Quizzes : optional
  Quizzes ||--o{ Questions : contains
  Questions ||--o{ AnswerOptions : offers
  Quizzes ||--o{ QuizAttempts : attempted
  Users ||--o{ QuizAttempts : makes
  QuizAttempts ||--o{ QuizAnswers : records
```

```
  Questions ||--o{ QuizAnswers : answered
  AnswerOptions ||--o{ QuizAnswers : chosen
  Enrollments ||--o| Certificates : earns
  Courses ||--o{ Reviews : receives
  Users ||--o{ Reviews : writes
  Users ||--o{ Notifications : receives
```

2. Từ điển dữ liệu

Ký hiệu: **PK** khóa chính, **FK** khóa ngoại, **UQ** unique, **IX** index, **CK** check.

Users (ASP.NET Identity + mở rộng)

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
UserName, NormalizedUserName	nvarchar(256)	UQ NormalizedUserName
Email, NormalizedEmail	nvarchar(256)	IX NormalizedEmail
PasswordHash, SecurityStamp, ConcurrencyStamp, PhoneNumber…	(Identity)	
FullName	nvarchar(150)	NOT NULL
AvatarUrl	nvarchar(500)	
Headline	nvarchar(200)	Chức danh giảng viên
Bio	nvarchar(max)	
IsActive	bit	DEFAULT 1
CreatedAt, UpdatedAt	datetime2	

Roles / UserRoles

`Roles(Id PK, Name, NormalizedName UQ, Description)`; `UserRoles(UserId FK, RoleId FK, PK(UserId, RoleId))`. Dữ liệu: `Admin`, `Instructor`, `Student`.

RefreshTokens

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
UserId	uniqueidentifier	FK → Users (CASCADE), IX
TokenHash	nvarchar(128)	UQ — SHA-256 của token, không lưu token gốc

Cột	Kiểu	Ràng buộc
ExpiresAt, CreatedAt, RevokedAt	datetime2	
CreatedByIp, RevokedByIp	nvarchar(64)	
ReplacedByTokenHash	nvarchar(128)	Chuỗi rotation

Categories

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
ParentId	uniqueidentifier	FK → Categories (NO ACTION)
Name	nvarchar(100)	NOT NULL
Slug	nvarchar(120)	UQ
Description	nvarchar(500)	
IconUrl	nvarchar(500)	
DisplayOrder	int	DEFAULT 0
IsActive	bit	DEFAULT 1

Courses

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
InstructorId	uniqueidentifier	FK → Users, IX
CategoryId	uniqueidentifier	FK → Categories, IX
Title	nvarchar(200)	NOT NULL
Slug	nvarchar(220)	UQ
ShortDescription	nvarchar(500)	
Description	nvarchar(max)	HTML đã sanitize
Requirements, Outcomes	nvarchar(max)	JSON mảng chuỗi
ThumbnailUrl, PreviewVideoUrl	nvarchar(500)	
Language	nvarchar(10)	DEFAULT 'vi'
Level	nvarchar(20)	CK IN (Beginner, Intermediate, Advanced)

Cột	Kiểu	Ràng buộc
Price	decimal(18,2)	CK ≥ 0
DiscountPrice	decimal(18,2)	CK NULL hoặc 0 ≤ x ≤ Price
Status	nvarchar(20)	CK IN (Draft, Pending, Published, Rejected); IX (Status, PublishedAt)
RejectionReason	nvarchar(1000)	
IsFeatured	bit	
SubmittedAt, PublishedAt	datetime2	
TotalDurationSeconds, TotalLessons	int	Denormalized, cập nhật khi sửa bài
EnrollmentCount, ReviewCount	int	Denormalized
AverageRating	decimal(3,2)	
IsDeleted	bit	Global query filter
CreatedAt, UpdatedAt	datetime2	
RowVersion	rowversion	Optimistic concurrency

CourseSections

`Id PK, CourseId FK→Courses (CASCADE), Title nvarchar(200), Description nvarchar(1000), SortOrder int`; IX `(CourseId, SortOrder)`.

Lessons

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
SectionId	uniqueidentifier	FK → CourseSections (CASCADE)
Title	nvarchar(200)	
Type	nvarchar(20)	CK IN (Video, Article)
Content	nvarchar(max)	Bài viết/ghi chú
VideoUrl	nvarchar(500)	
VideoPublicId	nvarchar(300)	ID Cloudinary để ký URL
DurationSeconds	int	CK ≥ 0

Cột	Kiểu	Ràng buộc
SortOrder	int	IX (SectionId, SortOrder)
IsPreview	bit	Cho xem miễn phí
IsRequired	bit	DEFAULT 1, tính điều kiện chứng chỉ

LessonResources

`Id PK, LessonId FK→Lessons (CASCADE), FileName nvarchar(255), FileUrl nvarchar(500), PublicId nvarchar(300), ContentType nvarchar(100), FileSize bigint CK ≥ 0, CreatedAt`.

Enrollments

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
UserId	uniqueidentifier	FK → Users
CourseId	uniqueidentifier	FK → Courses
OrderId	uniqueidentifier	FK → Orders (NULL nếu Admin cấp)
EnrolledAt	datetime2	
ProgressPercent	decimal(5,2)	CK 0–100
LastLessonId	uniqueidentifier	FK → Lessons (NO ACTION)
LastAccessedAt, CompletedAt	datetime2	
Status	nvarchar(20)	Active, Completed, Revoked
		UQ (UserId, CourseId) — chống mua trùng

LessonProgress

`Id PK, EnrollmentId FK→Enrollments (CASCADE), LessonId FK→Lessons (NO ACTION), IsCompleted bit, CompletedAt, LastPositionSeconds int, UpdatedAt`; **UQ (EnrollmentId, LessonId)**.

Carts / CartItems

`Carts(Id PK, UserId FK UQ, UpdatedAt)`; `CartItems(Id PK, CartId FK CASCADE, CourseId FK, AddedAt, UQ(CartId, CourseId))`.

Orders

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
OrderCode	varchar(20)	UQ — gửi sang cổng làm `vnp_TxnRef`
UserId	uniqueidentifier	FK → Users, IX (UserId, CreatedAt)
CouponId	uniqueidentifier	FK → Coupons
CouponCode	nvarchar(50)	Ảnh chụp
SubTotal, DiscountAmount, TotalAmount	decimal(18,2)	CK ≥ 0, TotalAmount = SubTotal − DiscountAmount
Status	nvarchar(20)	Pending, Paid, Cancelled, Expired, Refunded; IX
CreatedAt, PaidAt, CancelledAt, ExpiresAt	datetime2	
RowVersion	rowversion	

OrderItems

`Id PK, OrderId FK CASCADE, CourseId FK, CourseTitle nvarchar(200), InstructorId uniqueidentifier, OriginalPrice, Price, DiscountAllocated, FinalPrice decimal(18,2)` ; **UQ (OrderId, CourseId)**.

Payments

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
OrderId	uniqueidentifier	FK → Orders, IX
Provider	nvarchar(20)	VNPay, MoMo, Free
Amount	decimal(18,2)	
Status	nvarchar(20)	Pending, Success, Failed
TransactionRef	varchar(50)	UQ — mã gửi cổng
ProviderTransactionId	varchar(100)	**UQ (Provider, ProviderTransactionId) WHERE NOT NULL** — idempotency
BankCode, ResponseCode	nvarchar(20)	
RawResponse	nvarchar(max)	Đã loại bỏ dữ liệu nhạy cảm; không lưu số thẻ
CreatedAt, PaidAt	datetime2	

Coupons

`Id PK, Code nvarchar(50) UQ, Description, DiscountType (Percentage|FixedAmount), DiscountValue decimal CK > 0, MaxDiscountAmount, MinOrderAmount, UsageLimit int NULL, UsedCount int, PerUserLimit int, CourseId FK NULL (NULL = áp toàn sàn), StartsAt, ExpiresAt CK ExpiresAt > StartsAt, IsActive, CreatedAt`; CK Percentage ⇒ DiscountValue ≤ 100.

Quizzes / Questions / AnswerOptions

- `Quizzes(Id PK, CourseId FK CASCADE, SectionId FK NULL NO ACTION, Title, Description, PassingScore decimal(5,2) CK 0–100, MaxAttempts int NULL, TimeLimitMinutes int NULL, IsRequired bit, IsFinalExam bit, ShuffleQuestions bit, SortOrder, CreatedAt)`
- `Questions(Id PK, QuizId FK CASCADE, Content nvarchar(2000), Type (SingleChoice|MultipleChoice|TrueFalse), Points decimal(5,2) CK > 0, Explanation, SortOrder)`
- `AnswerOptions(Id PK, QuestionId FK CASCADE, Content nvarchar(1000), IsCorrect bit, SortOrder)`

QuizAttempts / QuizAnswers

- `QuizAttempts(Id PK, QuizId FK, UserId FK, AttemptNumber int, StartedAt, SubmittedAt, Score, MaxScore, ScorePercent decimal(5,2), IsPassed bit)`; **UQ (QuizId, UserId, AttemptNumber)**.
- `QuizAnswers(Id PK, AttemptId FK CASCADE, QuestionId FK NO ACTION, AnswerOptionId FK NO ACTION, IsCorrect bit)`; UQ (AttemptId, QuestionId, AnswerOptionId). Mỗi đáp án được chọn là một dòng.

Certificates

Cột	Kiểu	Ràng buộc
Id	uniqueidentifier	PK
CertificateCode	varchar(30)	UQ
UserId, CourseId	uniqueidentifier	FK; **UQ (UserId, CourseId)**
EnrollmentId	uniqueidentifier	FK → Enrollments, UQ
StudentName, CourseTitle, InstructorName	nvarchar	Ảnh chụp tại thời điểm cấp
FinalScore	decimal(5,2)	
PdfUrl	nvarchar(500)	
IssuedAt, RevokedAt	datetime2	
IsRevoked	bit	
RevokedReason	nvarchar(500)	

Reviews

`Id PK, CourseId FK, UserId FK, Rating tinyint CK 1–5, Comment nvarchar(2000), IsHidden bit, InstructorReply nvarchar(2000), RepliedAt, CreatedAt, UpdatedAt` ; **UQ (CourseId, UserId)**; IX (CourseId, CreatedAt).

Notifications

`Id PK, UserId FK CASCADE, Title nvarchar(200), Message nvarchar(1000), Type (System|Order|Course|Certificate|Review), Link nvarchar(500), IsRead bit, CreatedAt, ReadAt` ; IX (UserId, IsRead, CreatedAt).

3. Chuẩn hóa

- 3NF cho dữ liệu nghiệp vụ. Các cột ảnh chụp (`OrderItems.Price` , `Certificates.StudentName` ...) là **cố ý** để giữ giá trị lịch sử, không phải trùng lặp.
- Cột đếm (`EnrollmentCount` , `AverageRating`) là denormalization có kiểm soát để trang chủ truy vấn nhanh; cập nhật trong cùng transaction với thao tác gốc.

04 — Chạy dự án trên máy tính

Có hai cách chạy:

Cách	Khi nào dùng	Cần cài
A. Chế độ demo (SQLite)	Xem thử, phát triển giao diện, chạy E2E	.NET 10 SDK, Node.js 22+
B. SQL Server	Giống môi trường thật, kiểm tra migration	Thêm SQL Server 2022 (Developer/Express) hoặc LocalDB

1. Cài đặt công cụ (Windows)

```
winget install Microsoft.DotNet.SDK.10
winget install OpenJS.NodeJS.LTS
dotnet tool install --global dotnet-ef
# Chỉ cho cách B:
winget install Microsoft.SQLServer.2022.Developer
```

Không có quyền Admin thì cài .NET vào thư mục người dùng:

```
Invoke-WebRequest https://dot.net/v1/dotnet-install.ps1 -OutFile dotnet-install.ps1
.\dotnet-install.ps1 -Channel 10.0 -InstallDir "$env:USERPROFILE\.dotnet"
# Thêm %USERPROFILE%\.dotnet và %USERPROFILE%\.dotnet\tools vào PATH
```

Kiểm tra: `dotnet --list-sdks` (có 10.0.x), `node -v` (≥ 22).

2. Cấu hình bí mật (một lần)

Bí mật không nằm trong mã nguồn mà lưu bằng User Secrets:

```
cd src\backend\src\OnlineLearning.API
dotnet user-secrets set "Jwt:SecretKey" "<chuỗi ngẫu nhiên ≥ 32 ký tự>"
dotnet user-secrets set "Seed:DemoPassword" "<mật khẩu demo, ≥8 ký tự, có hoa/thường/số>"
```

Sinh chuỗi ngẫu nhiên trong PowerShell: `[Convert]::ToBase64String((1..48 | % { Get-Random -Max 256 }))`.

3. Cách A — chế độ demo (không cần SQL Server)

```
# Terminal 1: API (http://localhost:5080). Tự tạo eduviet-demo.db và dữ liệu mẫu.
cd src\backend\src\OnlineLearning.API
dotnet run --launch-profile demo-sqlite

# Terminal 2: Frontend (http://localhost:5173)
cd src\frontend\online-learning-client
npm install
npm run dev
```

Muốn tạo lại dữ liệu mẫu từ đầu: dừng API, xóa `eduviet-demo.db`, chạy lại.

> Chế độ demo tạo DB bằng `EnsureCreated` nên **không tự cập nhật khi schema đổi**. Sau khi kéo code có migration mới (ví dụ `InstructorProfileAndMessaging`), hãy dừng API rồi đổi tên/xóa `eduviet-demo.db` để DB được tạo lại kèm dữ liệu mẫu.

4. Cách B — SQL Server

```
cd src\backend
# Nếu không dùng instance mặc định (localhost), đặt chuỗi kết nối:
dotnet user-secrets --project src\OnlineLearning.API set "ConnectionStrings:DefaultConnection" "Server=.\SQLEXPRESS;Da
dotnet ef database update -p src\OnlineLearning.Infrastructure -s src\OnlineLearning.API
dotnet run --project src\OnlineLearning.API --launch-profile https
```

- Swagger: https://localhost:7080/swagger. Frontend vẫn gọi API qua http://localhost:5080.
- Nếu dùng LocalDB: `Server=(localdb)\MSSQLLocalDB;Database=OnlineLearningDb;Trusted_Connection=True;TrustServerCertificate=True`.
- DBA muốn chạy tay thì dùng script `setup/database/migration-InitialCreate.sql`.

5. Tài khoản demo

Mật khẩu chung là giá trị `Seed:DemoPassword`.

Email	Vai trò
`admin@eduviet.local`	Admin
`giangvien@eduviet.local`, `lethu.design@eduviet.local`, `phamquang.data@eduviet.local`	Giảng viên

Email	Vai trò
`hocvien@eduviet.local`, `hoangnam@…`, `ngoclan@…`, `minhtuan@…`, `baoanh@…`, `ducthinh@…`	Học viên

Mã giảm giá mẫu: `CHAOBANMOI`, `GIAM50K`, `MIENPHI100`. Thanh toán: chọn "Kênh thanh toán thử nghiệm" (tự thành công, không thu tiền).

6. Chạy kiểm thử

```
# Backend: 30 test tích hợp (SQLite in-memory, không cần SQL Server)
cd src\backend
dotnet test

# E2E: Playwright tự khởi động API demo (cổng 5081) + Vite (cổng 5174) với DB mới
cd src\frontend\online-learning-client
$env:E2E_CHANNEL="chrome"   # dùng Chrome đã cài; bỏ dòng này nếu đã chạy: npx playwright install chromium
npm run test:e2e
npm run test:e2e:report     # xem báo cáo HTML
```

Phải dừng API demo đang chạy trước khi chạy E2E, vì lệnh `dotnet run` cần build lại dự án.

7. Sự cố thường gặp

Lỗi	Cách xử lý
`Jwt:SecretKey phải dài ít nhất 32 ký tự`	Chưa đặt User Secrets (mục 2)
Frontend báo "Không kết nối được máy chủ"	API chưa chạy ở cổng 5080
`A network-related or instance-specific error`	Sai tên SQL Server trong chuỗi kết nối, hoặc service SQL Server chưa chạy
`The certificate chain was issued by an authority that is not trusted`	Thêm `TrustServerCertificate=True` vào chuỗi kết nối
`dotnet ef` không nhận	Mở terminal mới, hoặc thêm `%USERPROFILE%\.dotnet\tools` vào PATH
Build báo tệp DLL đang bị khóa	Dừng tiến trình API đang chạy rồi build lại
PDF chứng chỉ mất dấu tiếng Việt (Linux)	Cài `fonts-dejavu-core` hoặc `fonts-noto-core`

05 — Design system

Nguồn token: `src/frontend/online-learning-client/src/index.css` (Tailwind v4 `@theme`). Trang xem trước: chạy frontend và mở http://localhost:5173.

Màu

Lấy cảm hứng từ cổng tuyển sinh Đại học Văn Hiến: xanh dương rực, nền trắng/xanh rất nhạt, điểm nhấn cam và vàng nắng.

Vai trò	Token	Hex	Dùng cho
Chính	`brand-600`	#005CF8	Nút chính, liên kết, khối hero
Chính đậm	`brand-700`	#004DC1	Hover, mặt phẳng trên nền xanh
Nền nhạt	`brand-50`	#EFF6FF	Nền khu vực, nút phụ
Nhấn	`accent-500`	#EF8000	Hành động mua, giá khuyến mãi — **chữ màu ink**, không dùng chữ trắng (tương phản 2.7:1)
Vàng	`sun-300`	#FFDC7C	Nhãn "Bán chạy", highlight
Chữ	`ink`	#0B1B33	Văn bản chính
Chữ phụ	`ink-muted`	#6B7686	Ghi chú, metadata
Mặt phẳng	`surface`, `surface-2`, `surface-3`	#FFF, #F3F6FB, #E8EEF7	Tách vùng bằng bậc tông
Trạng thái	`success`, `warning`, `danger` (+ `-50`)		Toast, badge trạng thái đơn hàng/khóa học

Tương phản đã kiểm: trắng trên `brand-600` = 5.4:1 (AA), `ink` trên `accent-500` ≈ 7:1.

Chữ

- Một họ chữ: **Be Vietnam Pro** (400–800), thiết kế cho tiếng Việt, dấu không bị chồng.
- Cỡ: `text-display` (40→88px, -0.035em, leading 1), `text-title` (28→44px), thân bài 16–18px, leading 1.6.
- Căn trái mặc định; tiêu đề tối đa 2 dòng.

Thành phần

- Nút: phẳng, một màu, pill (`--radius-control`), cao ≥ 44px, nhấn co `scale(0.97)` trong 140ms `ease-out-strong`. Biến thể: `btn-primary`, `btn-accent`, `btn-soft`, `btn-ghost`.
- Thẻ: bo 12px (`--radius-card`), tách nền bằng `surface-2`; không shadow khi tĩnh, chỉ menu/dialog nổi mới có shadow.
- Không gradient, không glassmorphism, không icon trong ô màu lặp lại, không nhãn chữ hoa nhỏ giãn cách.

Chuyển động (theo nguyên tắc của Emil Kowalski)

- Chỉ animate `transform` và `opacity`; dùng `ease-out` cho phần tử xuất hiện, không dùng `ease-in`.
- UI tương tác ≤ 250ms; không animate thao tác bàn phím lặp lại.
- Tôn trọng `prefers-reduced-motion` (đã có trong base layer).

Áp dụng cho các màn hình

- **Trang công khai** (trang chủ, chi tiết khóa học): theo quy trình taste-skill — hero chiếm trọn màn đầu với màu `brand-600`, ảnh thật của khóa học, mỗi section một bố cục khác nhau.
- **Dashboard** (học viên/giảng viên/admin): nền `surface-2`, panel trắng, biểu đồ Recharts dùng `brand-600` cho chuỗi chính và `accent-500` cho chuỗi so sánh.

06 — Backend API (Giai đoạn 2)

Swagger: `https://localhost:7080/swagger` (Development). Mọi lỗi trả về `ProblemDetails` (`title` là thông báo tiếng Việt, `code` là mã lỗi, `errors` cho lỗi validation). Enum trả về dạng chuỗi (`"Published"`, `"Paid"`…).

1. Cấu trúc mã nguồn

```
src/OnlineLearning.Application/
  Common/        Result, PagedQuery, Options, Helpers (Slug, mã đơn, lọc HTML), Interfaces
  Features/
    Auth/            AuthService (đăng ký, đăng nhập, refresh xoay vòng, quên/đặt lại mật khẩu, hồ sơ)
    Categories/      CategoryService (cây 2 cấp)
    Courses/         CatalogService (công khai), InstructorCourseService, CourseModerationService
    Orders/          CartService, PricingService, OrderService, OrderFulfillmentService, CouponService, ReviewService
    Notifications/   NotificationService
    Admin/           AdminService (tổng quan, người dùng, vai trò)
src/OnlineLearning.Infrastructure/
  Identity/      JwtTokenService, VietnameseIdentityErrorDescriber
  Email/         SmtpEmailSender (không cấu hình Host → chỉ ghi log)
  BackgroundJobs/OrderExpiryService (5 phút/lần chuyển đơn quá hạn sang Expired)
  Persistence/   AppDbContext, Configurations, Migrations/InitialCreate, Seed/
src/OnlineLearning.API/
  Common/        ApiControllerBase (Result → HTTP), CurrentUser, ValidationFilter, GlobalExceptionHandler
  Controllers/   Auth, Account, Home, Categories, Courses, Instructors, Instructor, Cart, Orders, Notifications, Admin
tests/OnlineLearning.IntegrationTests/  16 kịch bản end-to-end trên SQLite in-memory
```

2. Danh sách endpoint

Công khai

Method	Đường dẫn	Mô tả
GET	`/api/home`	Nổi bật, mới nhất, bán chạy, danh mục, giảng viên nổi bật, đánh giá tiêu biểu, thống kê
GET	`/api/categories` · `/api/categories/{slug}`	Cây danh mục
GET	`/api/courses?keyword=&category=&level=&minPrice=&maxPrice=&minRating=&free=&sort=&page=&pageSize=`	Tìm kiếm; `sort`: `newest`, `popular`, `rating`, `price_asc`, `price_desc`
GET	`/api/courses/{slug}`	Chi tiết + đề cương (chỉ lộ URL video của bài preview), `isEnrolled`, `isInCart`, phân bố sao
GET	`/api/courses/{courseId}/reviews`	Đánh giá (phân trang)
GET	`/api/instructors/featured` · `/api/instructors/{id}`	Giảng viên

Tài khoản

Method	Đường dẫn	Ghi chú
POST	`/api/auth/register` · `/api/auth/login`	Trả `accessToken` (15 phút) + đặt cookie `eduviet_rt` HttpOnly (7 ngày)
POST	`/api/auth/refresh`	Xoay vòng refresh token; dùng lại token cũ → thu hồi mọi phiên
POST	`/api/auth/logout`	Thu hồi refresh token

Method	Đường dẫn	Ghi chú
POST	`/api/auth/forgot-password` · `/api/auth/reset-password` · `/api/auth/confirm-email`	Luôn 204 với forgot-password
GET	`/api/auth/me`	Người dùng hiện tại
GET/PUT	`/api/account/profile`	Hồ sơ
POST	`/api/account/change-password`	Đăng xuất các thiết bị khác

Học viên (cần đăng nhập)

Method	Đường dẫn	Ghi chú
GET/DELETE	`/api/cart`	Giỏ hàng (tự loại khóa đã mua/ngừng bán)
POST/DELETE	`/api/cart/items` · `/api/cart/items/{courseId}`	
POST	`/api/orders/quote`	`{ courseIds, couponCode }` → giá do server tính
POST	`/api/orders`	`{ courseIds | fromCart, couponCode, note }` — **không có trường giá**. Tổng 0đ → Paid ngay
GET	`/api/orders` · `/api/orders/{id}`	Lịch sử mua hàng
POST	`/api/orders/{id}/cancel`	Hủy đơn Pending
GET/POST/PUT/DELETE	`/api/courses/{courseId}/reviews[/me]`	Đánh giá (cần sở hữu khóa học)
GET/POST	`/api/notifications`, `/unread-count`, `/{id}/read`, `/read-all`	Thông báo

Giảng viên (`Instructor` hoặc `Admin`)

Method	Đường dẫn
GET/POST	`/api/instructor/courses`
GET/PUT/DELETE	`/api/instructor/courses/{id}`
POST	`/api/instructor/courses/{id}/submit` · `/unpublish`
POST · PUT	`/api/instructor/courses/{courseId}/sections` · `/sections/order`
PUT/DELETE	`/api/instructor/sections/{id}`
POST · PUT	`/api/instructor/sections/{id}/lessons` · `/lessons/order`

Method	Đường dẫn
PUT/DELETE	`/api/instructor/lessons/{id}`
POST · DELETE	`/api/instructor/lessons/{id}/resources` · `/api/instructor/resources/{id}`
GET · POST	`/api/instructor/reviews` · `/api/instructor/reviews/{id}/reply`

Admin

Method	Đường dẫn
GET	`/api/admin/overview` (doanh thu, đơn, người dùng 12 tháng)
GET · PUT · PUT	`/api/admin/users` · `/users/{id}/roles` · `/users/{id}/active`
GET · POST	`/api/admin/courses?status=Pending` · `/courses/{id}/approve` · `/reject` · `/unpublish`
PUT	`/api/admin/courses/{id}/featured`
GET/POST/PUT/DELETE	`/api/admin/categories[/{id}]`
GET/POST/PUT/DELETE	`/api/admin/coupons[/{id}]`
GET	`/api/admin/orders` · `/api/admin/orders/{id}`
PUT	`/api/admin/reviews/{id}/hidden`

3. Quy tắc nghiệp vụ đã thực thi trong code

Quy tắc	Nơi thực thi
BR-01 giá thực = giá KM nếu nhỏ hơn giá gốc	`Course.EffectivePrice`, `CatalogService.ToSummary`
BR-02 không mua khóa đã sở hữu / của chính mình / chưa xuất bản	`PricingService.CalculateAsync`, `CartService.AddAsync`
BR-03 không ghi danh trùng	Unique `(UserId, CourseId)` + kiểm tra trong `OrderFulfillmentService`
BR-04 giá ảnh chụp	`OrderItem.Price/FinalPrice`
BR-05 coupon %/cố định, trần, tối thiểu, phạm vi khóa, lượt/người	`Coupon.CalculateDiscount`, `PricingService` (phân bổ giảm giá theo tỷ lệ)
BR-06/07 idempotent, khớp số tiền	`OrderFulfillmentService.MarkPaidAsync` (transaction; đơn đã Paid → bỏ qua; sai số tiền → từ chối)
BR-09 đánh giá cần sở hữu, 1 lần	`ReviewService.CreateAsync` + unique index
BR-11 xóa mềm khi có lịch sử	`InstructorCourseService.DeleteAsync`

Quy tắc	Nơi thực thi
Nội dung chỉ sửa khi Draft/Rejected	`Course.IsEditable`
XSS	`ContentSanitizer` (HtmlSanitizer) cho mô tả khóa học và bài viết
Lượt dùng coupon chỉ tính khi đơn **Paid**	Đơn hết hạn/hủy không tốn lượt

`MarkPaidAsync` là điểm duy nhất cấp quyền học. Giai đoạn 5 (VNPay/MoMo) chỉ gọi hàm này sau khi xác thực chữ ký IPN.

4. Kiểm thử

```
cd src\backend
dotnet test
```

16 kịch bản chạy toàn bộ pipeline thật (controller → service → EF Core) trên SQLite in-memory với dữ liệu mẫu: trang chủ, tìm kiếm/lọc/sắp xếp, ẩn video không preview, ẩn khóa Pending; đăng ký, refresh xoay vòng, phát hiện tái sử dụng token, đăng xuất, sai mật khẩu, validation, đổi mật khẩu, phân quyền 401/403; giỏ hàng, báo giá, chống sửa giá, mã giảm giá, đơn 0đ cấp quyền, chặn mua trùng, đánh giá một lần; giảng viên tạo khóa → gửi duyệt → bị từ chối → duyệt, khóa chỉnh sửa khi Pending, cô lập giữa giảng viên; admin tổng quan, vai trò, khóa tài khoản, mã giảm giá, danh mục.

5. Dữ liệu mẫu

Loại	Nội dung
Tài khoản	`admin@eduviet.local`; giảng viên `giangvien@`, `lethu.design@`, `phamquang.data@`; học viên `hocvien@`, `hoangnam@`, `ngoclan@`, `minhtuan@`, `baoanh@`, `ducthinh@` (đuôi `@eduviet.local`), mật khẩu = `Seed:DemoPassword`
Khóa học	10 khóa Published (1 khóa miễn phí) + 1 khóa Pending để demo kiểm duyệt; ảnh từ picsum.photos, video mẫu công khai
Đơn hàng	~40 đơn Paid rải 10 tháng (có dữ liệu cho biểu đồ doanh thu), kèm đánh giá và phản hồi
Mã giảm giá	`CHAOBANMOI` (10%, tối đa 100k), `GIAM50K` (đơn từ 300k), `MIENPHI100` (100% — demo đơn 0đ)

Ảnh, video và tài liệu mẫu là placeholder; sẽ thay bằng Cloudinary ở Giai đoạn 5.

07 — Frontend (Giai đoạn 3)

React 19 + TypeScript + Vite 8 + Tailwind CSS v4 + React Router 7 + Axios. Thông báo: Sonner. Lọc HTML: DOMPurify. Icon: lucide-react.

1. Chạy

```
# Terminal 1 — API, chế độ demo không cần SQL Server (SQLite file eduviet-demo.db, tự seed dữ liệu mẫu)
cd src\backend\src\OnlineLearning.API
dotnet user-secrets set "Jwt:SecretKey" "<chuỗi ngẫu nhiên ≥ 32 ký tự>"
dotnet user-secrets set "Seed:DemoPassword" "<mật khẩu demo, có hoa/thường/số>"
dotnet run --launch-profile demo-sqlite

# Terminal 2 — Frontend
cd src\frontend\online-learning-client
npm install
npm run dev
```

Mở http://localhost:5173. Vite proxy chuyển `/api/*` tới `http://localhost:5080` (đổi bằng biến `API_PROXY_TARGET`). Dùng SQL Server thật: chạy profile `https` thay cho `demo-sqlite` (cả hai đều mở http://localhost:5080).

2. Trang

Đường dẫn	Trang	Ghi chú
`/`	Trang chủ	Hero "chứng chỉ" (gõ tên để in lên chứng chỉ mẫu), lĩnh vực, nổi bật, bán chạy, phiếu thư viện, mới xuất bản, giảng viên, đánh giá, lời mời đăng ký
`/khoa-hoc`	Danh sách	Tìm kiếm, lọc lĩnh vực/cấp độ/giá/đánh giá, sắp xếp, phân trang; trạng thái lọc nằm trên URL
`/khoa-hoc/:slug`	Chi tiết	Thẻ mua hàng dính, xem thử video preview, đề cương, mô tả (DOMPurify), giảng viên, phân bố sao, đánh giá, viết/sửa đánh giá khi đã sở hữu
`/giang-vien/:id`	Hồ sơ giảng viên	
`/dang-nhap`, `/dang-ky`, `/quen-mat-khau`, `/dat-lai-mat-khau`, `/xac-nhan-email`	Tài khoản	Quay lại trang trước qua `?next=` (chỉ chấp nhận đường dẫn nội bộ)

Đường dẫn	Trang	Ghi chú
`/gio-hang`	Giỏ hàng	Cần đăng nhập
`/thanh-toan[?course=id]`	Thanh toán	Báo giá từ server, mã giảm giá, đơn 0đ hoàn tất ngay
`/don-hang/:id`	Đơn hàng	Hóa đơn, đếm ngược hết hạn, hủy đơn
`/tai-khoan`, `/tai-khoan/don-hang`	Hồ sơ, đổi mật khẩu, lịch sử mua hàng	

3. Xác thực phía client

- Access token chỉ giữ **trong bộ nhớ** (`tokenStore`), không dùng localStorage.
- Refresh token ở cookie HttpOnly. Khi tải trang, `AuthProvider` gọi `/api/auth/refresh` để khôi phục phiên; cứ 12 phút làm mới một lần.
- Interceptor Axios: gặp 401 → refresh một lần (gộp các request song song) → gửi lại.
- `ProtectedRoute` chặn trang cần đăng nhập/vai trò.

Lần tải đầu khi chưa đăng nhập, console có một dòng 401 từ `/api/auth/refresh`: đây là kiểm tra phiên, không phải lỗi.

4. Thiết kế

Hướng thiết kế lấy từ taste-skill (seed 1677846207), hướng **"Trang chính là vật thể"**: *chứng chỉ có mã xác minh của EduViet trở thành tấm thẻ ở hero*. Các phần tiếp theo là giấy tờ cùng bộ: phiếu thư viện (mép răng cưa, cộng đúng tổng số khóa học), đánh giá in trên mẩu giấy xé, thẻ hồi đáp nghiêng, chân trang là mặt sau tấm thiệp với mép vỏ sò.

- Màu: xanh `#005CF8` / `#004DC1`, cam `#EF8000`, vàng `#FFDC7C`, nền `#EFF6FF` (tham khảo tuyensinh.vhu.edu.vn).
- Không gradient, không đổ bóng khi tĩnh (chỉ menu, hộp thoại và thẻ mua hàng nổi), không viền trừ ô nhập và bảng.
- Chuyển động: hero trồi lên, ảnh nền trôi chậm, các phần tử từng section xuất hiện lần lượt (stagger 70ms), phản hồi khi nhấn nút (`scale(0.97)`); tôn trọng `prefers-reduced-motion`.
- Kết quả đo `inspect.mjs` trên bản build production của trang chủ: **0 FAIL**, 2 WARN có lý do (số cỡ chữ của trang thương mại; video nằm ở trang chi tiết khóa học).

Ảnh khóa học và ảnh nền là ảnh Unsplash qua picsum.photos (chỉ để minh họa), sẽ thay bằng ảnh thật qua Cloudinary ở Giai đoạn 5.

08 — Học trực tuyến, kiểm tra và dashboard (Giai đoạn 4)

1. Học trực tuyến

Đường dẫn	Mô tả
`/hoc/:slug`	Vào khóa học, tự chuyển tới bài nên học tiếp (bài gần nhất, hoặc bài đầu tiên chưa xong)
`/hoc/:slug/bai/:lessonId`	Video / bài viết, tài liệu tải về, đánh dấu hoàn thành, bài trước / bài sau
`/hoc/:slug/kiem-tra/:quizId`	Giới thiệu bài kiểm tra → làm bài (đồng hồ, tự nộp khi hết giờ) → kết quả + đáp án chi tiết + lịch sử

- Video tự lưu vị trí xem mỗi 15 giây và khi tạm dừng; mở lại sẽ tiếp tục từ vị trí cũ. Xem hết video thì bài tự được đánh dấu hoàn thành.
- % hoàn thành = số bài **bắt buộc** đã xong / tổng số bài bắt buộc.
- Khóa học chuyển sang **Completed** khi đủ 100% bài bắt buộc **và** đạt mọi bài kiểm tra bắt buộc. Nếu bỏ đánh dấu một bài, trạng thái quay về Active. Giai đoạn 6 sẽ cấp chứng chỉ tại thời điểm này.
- Giảng viên sở hữu khóa và Admin mở trình học ở **chế độ xem trước**: xem được mọi bài, không ghi tiến độ, không làm bài kiểm tra.
- Bảo vệ nội dung: chỉ bài học thử mở cho mọi người dùng đã đăng nhập. Các bài khác trả 403 nếu chưa ghi danh. URL video có chữ ký và hết hạn sẽ làm ở Giai đoạn 5 (Cloudinary).

2. Bài kiểm tra

Quy tắc	Cách thực hiện
Không lộ đáp án	API bắt đầu làm bài trả đề **không có** `isCorrect`; đáp án chỉ trả sau khi nộp
Chấm điểm ở server	Câu đúng khi tập đáp án chọn **trùng khớp** tập đáp án đúng; mỗi câu có điểm riêng
Giới hạn số lần (BR-10)	Mỗi lần bắt đầu tính một lượt; hết lượt trả 409; tải lại trang thì tiếp tục lượt đang làm
Thời gian	Hạn = lúc bắt đầu + giới hạn phút; nộp trễ quá 60 giây thì bị chấm 0 điểm; client tự nộp khi hết giờ
Nộp lặp	Nộp lại lượt đã nộp chỉ trả về kết quả cũ, không chấm lại

Quy tắc	Cách thực hiện
Toàn vẹn lịch sử	Khi đã có người làm, giảng viên chỉ sửa được thông tin chung và lời giải thích, không sửa được câu hỏi/đáp án, và không xóa được bài
Trộn câu hỏi	Trộn theo lượt làm (giữ nguyên thứ tự khi tải lại trang)

Loại câu hỏi: một đáp án, nhiều đáp án, đúng/sai (đúng 2 đáp án, 1 đáp án đúng). Mỗi câu có 2–10 đáp án.

3. Dashboard

Khu vực	Đường dẫn	Nội dung
Học viên	`/hoc-vien`	Số liệu (khóa đã mua, hoàn thành, số bài, bài kiểm tra đạt, tổng chi), ô "Tiếp tục học", khóa học theo trạng thái kèm tiến độ
	`/hoc-vien/ket-qua`, `/hoc-vien/chung-chi`	Lịch sử làm bài; danh sách chứng chỉ (PDF ở Giai đoạn 6)
	`/tai-khoan`, `/tai-khoan/don-hang`	Hồ sơ, lịch sử thanh toán
Giảng viên	`/giang-day`	Doanh thu, học viên, khóa học, đánh giá; biểu đồ doanh thu và lượt đăng ký 12 tháng; bảng theo khóa học kèm tiến độ trung bình
	`/giang-day/khoa-hoc[/:id]`	Danh sách và trang soạn khóa học: thông tin, chương/bài (sắp xếp, học thử, bắt buộc, tài liệu), bài kiểm tra; gửi duyệt / chuyển về nháp / xóa
	`/giang-day/hoc-vien`, `/giang-day/danh-gia`	Học viên và tiến độ; trả lời đánh giá
Admin	`/quan-tri`	Doanh thu, đơn hàng, người dùng, khóa học, lượt ghi danh, chứng chỉ; 3 biểu đồ 12 tháng
	`/quan-tri/khoa-hoc`	Duyệt / từ chối có lý do / gỡ khóa học / đặt nổi bật
	`/quan-tri/nguoi-dung`, `/danh-muc`, `/don-hang`, `/ma-giam-gia`	Phân quyền, khóa tài khoản; CRUD danh mục và mã giảm giá; tra cứu đơn hàng

Biểu đồ dùng Recharts: chuỗi chính màu `brand-600`, cột màu `accent-500`, trục và lưới màu trung tính, tooltip định dạng tiền Việt Nam.

4. API mới

Method	Đường dẫn
GET	`/api/learning/summary`, `/api/learning/courses?filter=all|in-progress|not-started|completed`
GET	`/api/learning/courses/{slug}`, `/api/learning/lessons/{id}`
POST/DELETE	`/api/learning/lessons/{id}/complete`
PUT	`/api/learning/lessons/{id}/position`
GET · POST	`/api/learning/quizzes/{id}` · `/api/learning/quizzes/{id}/attempts`
POST · GET	`/api/learning/attempts/{id}/submit` · `/api/learning/attempts/{id}`
GET	`/api/learning/quiz-results`, `/api/learning/certificates`
GET	`/api/instructor/overview`, `/api/instructor/students`
GET/POST	`/api/instructor/courses/{courseId}/quizzes`
GET/PUT/DELETE	`/api/instructor/quizzes/{id}`

5. Dữ liệu mẫu bổ sung

Mỗi khóa học đã xuất bản có một "Bài kiểm tra cuối khóa" gồm 5 câu, đạt 70%, tối đa 3 lượt, giới hạn 15 phút. Mỗi lượt ghi danh mẫu đã hoàn thành sẵn một phần bài học. Muốn tạo lại dữ liệu demo thì xóa `src/backend/src/OnlineLearning.API/eduviet-demo.db` rồi chạy lại API.

09 — Thanh toán & lưu trữ tệp (Giai đoạn 5)

1. Các phương thức thanh toán

Phương thức	Khi nào bật	Thu tiền thật?
Kênh thanh toán thử nghiệm	`Payments:TestGateway:Enabled = true` (bật sẵn trong `appsettings.Development.json`)	**Không**: tự động thành công
VNPay	Khi có `VnPay:TmnCode` và `VnPay:HashSecret`	Không với URL sandbox; có khi dùng URL production
MoMo	Khi có `MoMo:PartnerCode`, `AccessKey`, `SecretKey`	Không với endpoint `test-payment`; có khi dùng endpoint production

Trang thanh toán chỉ hiện các phương thức đang bật (`GET /api/payments/methods`). Khi khách chọn kênh thử nghiệm hoặc cổng sandbox, trang hiện thông báo:

> **Hiện tại đang trong giai đoạn test kênh thanh toán, chưa thu tiền thật.**

Thông báo này cũng hiện trên trang kết quả thanh toán và trang chi tiết đơn hàng đã trả qua kênh test.

Production phải tắt kênh thử nghiệm (`Payments__TestGateway__Enabled=false`, mặc định trong `appsettings.json`). Khi tắt, endpoint `/api/payments/test/gateway` trả 404.

2. Luồng thanh toán

```
sequenceDiagram
  participant FE as React
  participant API as API
  participant GW as Cổng (VNPay/MoMo/Test)
  FE->>API: POST /api/orders (giá do server tính)
  FE->>API: POST /api/payments/orders/{id}/checkout {provider}
  API->>API: Tạo Payment(Pending, TransactionRef mới)
  API-->>FE: redirectUrl (đã ký)
  FE->>GW: Chuyển trình duyệt
  GW->>API: IPN (server-to-server, có chữ ký)
  API->>API: Xác thực chữ ký → khớp số tiền → idempotency → MarkPaid → cấp quyền học
```

```
GW-->>FE: Chuyển về /thanh-toan/ket-qua?...
FE->>API: GET /api/payments/return/{provider}?... (chỉ đọc trạng thái)
```

Kênh thử nghiệm đi **đúng các bước trên**. "Cổng" `/api/payments/test/gateway` (do API phục vụ) kiểm tra chữ ký của yêu cầu, tạo IPN có chữ ký HMAC-SHA256 rồi đưa vào cùng hàm xử lý IPN của VNPay/MoMo. Nhờ vậy khi chuyển sang cổng thật, luồng cấp quyền không phải thay đổi gì.

Quy tắc bảo mật đã kiểm thử

Quy tắc	Thực hiện
Không tin giá từ Frontend	Request tạo đơn không có trường giá; số tiền gửi sang cổng lấy từ `Order.TotalAmount`
Xác thực chữ ký	VNPay HMAC-SHA512 trên query đã sắp xếp và URL-encode; MoMo HMAC-SHA256 theo chuỗi `accessKey=…&amount=…` . So sánh trong thời gian cố định
Khớp số tiền	Số tiền IPN phải bằng `Payment.Amount` và `Order.TotalAmount` ; lệch thì VNPay nhận `RspCode=04`
Idempotency	Giao dịch không còn ở trạng thái `Pending` thì bỏ qua (`02`); có unique index `(Provider, ProviderTransactionId)` ; `MarkPaidAsync` chạy trong transaction và bỏ qua nếu đơn đã `Paid`
Không cấp quyền qua redirect	`/api/payments/return/*` chỉ trả trạng thái để hiển thị. Test kiểm chứng: return báo thành công, đúng chữ ký, đơn vẫn `Pending`
Thanh toán thất bại	Payment chuyển `Failed` , đơn vẫn `Pending` để khách thanh toán lại
Thanh toán hai lần	Giao dịch thứ hai được ghi `Success` kèm log cảnh báo để đối soát hoàn tiền; không cấp quyền lần nữa
Không lưu dữ liệu thẻ	Chỉ lưu mã giao dịch, mã ngân hàng, mã phản hồi và tham số callback (không có số thẻ)
Chống spam	Rate limit 60 yêu cầu/phút/IP cho checkout và IPN

Mã phản hồi IPN VNPay: `00` thành công/đã ghi nhận thất bại, `01` không tìm thấy, `02` đã xử lý, `04` sai số tiền, `97` sai chữ ký, `99` lỗi khác. Tên trường giữ đúng `RspCode` / `Message` . MoMo IPN trả `204` , sai chữ ký trả `400` .

3. Cấu hình VNPay / MoMo sandbox

1. Đăng ký tài khoản sandbox: - VNPay: https://sandbox.vnpayment.vn/devreg — nhận `TmnCode` và `HashSecret` . - MoMo: https://developers.momo.vn — nhận `PartnerCode` , `AccessKey` , `SecretKey` .
2. Mở API ra Internet để cổng gọi được IPN về máy: `powershell ngrok http 5080`
3. Lưu khóa bằng User Secrets (không đưa vào mã nguồn): `powershell cd src\backend\src\OnlineLearning.API dotnet user-secrets set "VnPay:TmnCode" "<TmnCode>" dotnet user-secrets set "VnPay:HashSecret" "<HashSecret>" dotnet user-secrets set "VnPay:IpnUrl" "https://<ngrok>.ngrok-free.app/api/payments/vnpay/ipn" dotnet user-`

`secrets set "MoMo:PartnerCode" "<PartnerCode>" dotnet user-secrets set "MoMo:AccessKey" "<AccessKey>" dotnet user-secrets set "MoMo:SecretKey" "<SecretKey>" dotnet user-secrets set "MoMo:IpnUrl" "https://<ngrok>.ngrok-free.app/api/payments/momo/ipn"` Với VNPay, URL IPN còn phải được khai báo trong trang quản trị merchant sandbox.

4. `Payments:ReturnUrl` mặc định là `http://localhost:5173/thanh-toan/ket-qua`.
5. Thẻ test VNPay (ngân hàng NCB): số `9704198526191432198`, chủ thẻ `NGUYEN VAN A`, ngày phát hành `07/15`, OTP `123456`.

Nếu chưa mở ngrok, cổng sandbox vẫn chuyển khách về trang kết quả nhưng đơn sẽ ở trạng thái "Đang chờ xác nhận", vì IPN không tới được máy. Đây là hành vi đúng: hệ thống không cấp quyền dựa trên redirect.

4. Lưu trữ tệp

Loại	Giới hạn	Định dạng	Quyền tải lên	Truy cập
Ảnh	5 MB	JPG, PNG, WEBP, GIF	Mọi người dùng đã đăng nhập	Công khai
Video	500 MB	MP4, WEBM, MOV, M4V	Giảng viên, Admin	**Riêng tư**: URL có chữ ký, chỉ cấp cho người có quyền xem bài
Tài liệu	50 MB	PDF, ZIP, RAR, DOCX, XLSX, PPTX, TXT, MD	Giảng viên, Admin	**Riêng tư**: URL có chữ ký

Mỗi tệp được kiểm tra phần mở rộng, dung lượng và **chữ ký tệp (magic bytes)**: một tệp `.png` có nội dung là script sẽ bị từ chối.

Môi trường	Cách lưu
Có khóa Cloudinary	Ảnh lưu dạng `upload` (CDN công khai). Video/tài liệu lưu dạng `authenticated`; Backend tạo URL có chữ ký khi học viên đã ghi danh mở bài
Chưa có khóa (mặc định khi phát triển)	Ảnh lưu ở `wwwroot/uploads/images`. Video/tài liệu lưu ở `App_Data/storage` (không truy cập trực tiếp được), phát qua `/api/media/{id}?exp=…&sig=…` (HMAC, hết hạn sau 120 phút, hỗ trợ tua video)

Cấu hình Cloudinary:

```
dotnet user-secrets set "Cloudinary:CloudName" "<cloud name>"
dotnet user-secrets set "Cloudinary:ApiKey" "<api key>"
dotnet user-secrets set "Cloudinary:ApiSecret" "<api secret>"
```

URL `authenticated` có chữ ký của Cloudinary không đoán được nhưng không tự hết hạn. Muốn link có hạn dùng thì phải bật gói *Token-based authentication* của Cloudinary.

5. Giao diện

- **Thanh toán:** chọn phương thức, rồi "Đặt hàng và thanh toán" chuyển tới cổng. Đơn 0đ hoàn tất ngay.
- **Đơn hàng chờ thanh toán:** chọn phương thức và thanh toán lại trong thời gian còn hiệu lực.
- `/thanh-toan/ket-qua`**:** nhận biết cổng qua tham số, nhờ Backend xác thực chữ ký, rồi hỏi lại trạng thái đơn tối đa khoảng 15 giây nếu IPN tới chậm.
- **Soạn khóa học:** tải ảnh đại diện, tải video bài học (tự điền thời lượng khi dùng Cloudinary), tải tài liệu. Vẫn có thể dán URL như trước.
- **Hồ sơ:** tải ảnh đại diện.
- **Admin** `/quan-tri/giao-dich`**:** tra cứu và lọc giao dịch theo cổng và trạng thái.

6. Kiểm thử

`dotnet test`: 28 kịch bản, trong đó 9 kịch bản mới: - Kênh test thành công qua IPN có chữ ký; gọi lại không cấp quyền lần hai; URL bị sửa bị từ chối. - VNPay: chữ ký gửi đi đúng chuẩn; IPN sai chữ ký (97), sai số tiền (04), không tồn tại (01), hợp lệ (00), lặp (02); trang return không cấp quyền; thanh toán thất bại. - MoMo: IPN giả chữ ký bị từ chối, IPN đúng chữ ký thì cấp quyền. - Tải tệp: ảnh hợp lệ và dùng làm ảnh đại diện; tệp giả định dạng, đuôi cấm, học viên tải video đều bị chặn; video riêng tư chỉ phát qua URL có chữ ký, sửa chữ ký hoặc truy cập thẳng đều bị chặn.

10 — Chứng chỉ PDF & trang xác minh (Giai đoạn 6)

1. Điều kiện và cách cấp

- **Điều kiện (FR-CERT-01):** hoàn thành 100% bài học **bắt buộc** và **đạt** mọi bài kiểm tra bắt buộc của khóa.
- **Thời điểm cấp:** ngay khi điều kiện được thỏa, dù bước cuối là đánh dấu xong bài học hay nộp bài kiểm tra đạt (`LearningService.RecalculateAsync` gọi `CertificateService.IssueIfEligibleAsync`).
- **Idempotent:** mỗi lượt ghi danh chỉ có một chứng chỉ (unique `EnrollmentId` và `(UserId, CourseId)`). Bỏ đánh dấu một bài rồi hoàn thành lại vẫn giữ nguyên mã cũ. Hai yêu cầu đến cùng lúc sẽ bị unique index chặn bản thứ hai.
- **Mã chứng chỉ:** `EDV-YYYY-XXXXXXXX` , 8 ký tự ngẫu nhiên (bộ sinh số ngẫu nhiên an toàn), bỏ các ký tự dễ nhầm O/0/I/1/L.
- **Thông tin lưu cố định lúc cấp:** tên học viên, tên khóa học, tên giảng viên. Đổi tên sau này không làm thay đổi chứng chỉ đã cấp.
- **Điểm in trên chứng chỉ:** điểm cao nhất của bài thi cuối khóa; nếu không có bài thi cuối khóa thì lấy trung bình điểm cao nhất của các bài bắt buộc.
- Học viên nhận thông báo kèm mã chứng chỉ.
- Admin có nút **"Cấp bù chứng chỉ còn thiếu"** dành cho các lượt ghi danh đã hoàn thành trước khi tính năng này ra đời.

2. PDF

Sinh bằng **QuestPDF** (giấy phép Community, miễn phí cho tổ chức doanh thu dưới 1 triệu USD/năm) cùng **QRCoder**:

- Khổ A4 ngang, dải thương hiệu xanh, tên học viên cỡ lớn, khóa học, giảng viên, ngày cấp (giờ Việt Nam), điểm, thời lượng.
- Mã chứng chỉ kèm mã QR và liên kết tới `{App:ClientUrl}/xac-minh/{mã}` .
- Chứng chỉ đã thu hồi có dấu đỏ **"ĐÃ THU HỒI"** (chỉ Admin tải được bản này).
- PDF được tạo **khi tải**, không lưu tệp, nên luôn khớp với trạng thái hiện tại trong DB.

Font tiếng Việt: QuestPDF dùng font cài trên máy chủ, thứ tự ưu tiên Arial, Segoe UI, DejaVu Sans, Noto Sans, Liberation Sans. - Windows có sẵn Arial. - Linux/Docker cần cài font, ví dụ `apt-get install -y fonts-`

`dejavu-core` hoặc `fonts-noto-core`. - Muốn PDF giống hệt nhau trên mọi máy chủ, đặt tệp `.ttf` (ví dụ Be Vietnam Pro) vào thư mục `Fonts/` cạnh ứng dụng; font sẽ được đăng ký khi khởi động.

3. API

Method	Đường dẫn	Quyền	Mô tả
GET	`/api/learning/certificates`	Học viên	Chứng chỉ còn hiệu lực của tôi
GET	`/api/certificates/{id}/pdf`	Chủ sở hữu / Admin	Tải PDF
GET	`/api/certificates/verify/{code}`	Công khai	Xác minh, không phân biệt chữ hoa/thường
GET	`/api/certificates/verify/{code}/pdf`	Công khai	Tải PDF bản gốc (chỉ khi chứng chỉ còn hiệu lực)
GET	`/api/admin/certificates`	Admin	Tra cứu theo mã, tên, email, khóa học; lọc theo tình trạng
POST	`/api/admin/certificates/{id}/revoke` · `/restore`	Admin	Thu hồi (bắt buộc ghi lý do) / khôi phục
POST	`/api/admin/certificates/backfill`	Admin	Cấp bù chứng chỉ còn thiếu

Các endpoint xác minh công khai có giới hạn 60 yêu cầu/phút/IP để chống dò mã.

4. Giao diện

Trang	Nội dung
`/xac-minh`, `/xac-minh/:mã`	Trang công khai (có liên kết trên menu và chân trang). Nhập mã hoặc quét QR, kết quả hiển thị như một tấm chứng chỉ: dải xanh "hợp lệ" hoặc dải đỏ "đã thu hồi" kèm lý do; tải bản PDF gốc
`/hoc-vien/chung-chi`	Danh sách chứng chỉ của tôi: tải PDF, mở trang xác minh, sao chép liên kết để gửi nhà tuyển dụng
Trình học	Hoàn thành khóa thì hiện thông báo kèm nút "Xem chứng chỉ"; đề cương có liên kết "Xem và tải chứng chỉ"; trang kết quả bài kiểm tra hiện mã chứng chỉ
`/quan-tri/chung-chi`	Tra cứu, tải PDF, thu hồi có lý do (học viên nhận thông báo), khôi phục, cấp bù

5. Kiểm thử

30/30 test. Hai kịch bản mới: - Học xong khóa và đạt bài kiểm tra thì có đúng một chứng chỉ với mã đúng định dạng. Hoàn thành lại không cấp thêm. PDF hợp lệ (`%PDF`). Người khác không tải được bằng id. Xác minh công khai hoạt động, mã không tồn tại trả 404. Thu hồi thì trang xác minh báo đã thu hồi kèm lý do và PDF công khai bị chặn; khôi phục được. - Khóa chưa hoàn thành thì không có chứng chỉ; endpoint cấp bù hoạt động.

Đã chạy thử trên trình duyệt: học viên mẫu học hết khóa "Kỹ năng thuyết trình chuyên nghiệp", đạt bài kiểm tra và nhận chứng chỉ ngay. Mở PDF thấy dấu tiếng Việt, mã QR và đường dẫn xác minh hiển thị đúng.

11 — Triển khai lên môi trường thực tế

Ba phương án, chọn một:

Phương án	Phù hợp	Thành phần
A. Docker Compose trên VPS Linux (khuyến nghị)	Một máy chủ 2 vCPU / 4 GB RAM trở lên	SQL Server 2022 container, API, Nginx (frontend + reverse proxy)
B. Windows Server + IIS	Hạ tầng Windows có sẵn	IIS + ASP.NET Core Hosting Bundle, SQL Server
C. Azure	Không muốn tự quản máy chủ	App Service (API), Static Web Apps (frontend), Azure SQL

> Dockerfile và docker-compose đã viết nhưng **chưa build thử** trên máy phát triển vì máy này không có Docker. Hãy chạy `docker compose build` (trong thư mục `docker/`) ở môi trường có Docker trước khi đưa lên production.

Phương án A — Docker Compose

```
Internet ──HTTPS──> Caddy/Cloudflare (TLS) ──HTTP──> web (Nginx :80)
                                                      ├── /          → React (dist)
                                                      ├── /api/*     → api:8080
                                                      └── /uploads/* → api:8080
                                          api ──> sqlserver:1433 (không mở ra ngoài)
```

1. **Chuẩn bị máy chủ** (Ubuntu 24.04): cài Docker Engine + Compose plugin, mở cổng 80/443, trỏ DNS `eduviet.example.com` về máy chủ.
2. **Lấy mã nguồn và cấu hình:** `bash git clone <repo> eduviet && cd eduviet/docker cp .env.example .env nano .env # PUBLIC_URL, SQL_SA_PASSWORD, JWT_SECRET, ADMIN_EMAIL/ADMIN_PASSWORD, khóa VNPay/MoMo/Cloudinary/SMTP`
3. **Chạy:** `bash docker compose up -d --build docker compose logs -f api # chờ dòng "Application started" curl http://localhost/api/health` API tự áp dụng migration (`Database__MigrateOnStartup=true`), tạo vai trò, danh mục mặc định và tài khoản Admin từ `ADMIN_EMAIL` / `ADMIN_PASSWORD`. Sau lần chạy đầu, xóa `ADMIN_PASSWORD` khỏi `.env`.
4. **HTTPS:** đặt Caddy trước Nginx (tự xin chứng chỉ Let's Encrypt): `eduviet.example.com { reverse_proxy localhost:8081 header_up X-Forwarded-Proto https }` Khi đó đặt `HTTP_PORT=8081` và `HTTPS_REDIRECT=true` trong `.env`. Dùng Cloudflare cũng được, với chế độ SSL "Full".
5. **Cập nhật phiên bản:** `git pull && docker compose up -d --build`. Migration mới được áp dụng tự động.

6. **Sao lưu:** `bash docker compose exec sqlserver /opt/mssql-tools18/bin/sqlcmd -C -S localhost -U sa -P "$SQL_SA_PASSWORD" \ -Q "BACKUP DATABASE OnlineLearningDb TO DISK='/var/opt/mssql/backup/eduviet.bak' WITH INIT"` Sao lưu thêm volume `apidata` (khóa Data Protection + tệp riêng tư) và `uploads`, trừ khi đã dùng Cloudinary.

Phương án B — Windows Server + IIS

1. Cài **ASP.NET Core 10 Hosting Bundle**, **SQL Server 2022**, bật IIS và module **URL Rewrite**.
2. Build và publish: `powershell cd src\backend dotnet publish src\OnlineLearning.API -c Release -o C:\inetpub\eduviet-api cd ..\frontend\online-learning-client npm ci; npm run build # copy dist\* vào C:\inetpub\eduviet-web`
3. Áp dụng migration bằng *migration bundle* (không cần cài SDK trên máy chủ): `powershell dotnet ef migrations bundle -p src\OnlineLearning.Infrastructure -s src\OnlineLearning.API -o efbundle.exe .\efbundle.exe --connection "Server=...;Database=OnlineLearningDb;..."`
4. Tạo site IIS cho frontend (thư mục `eduviet-web`). Thêm `web.config` dùng URL Rewrite để: chuyển `api/*` và `uploads/*` sang API (ứng dụng con `/api`, hoặc ARR proxy tới site API), và trả `index.html` cho mọi đường dẫn còn lại (SPA).
5. Cấu hình API bằng **biến môi trường** trong Application Pool, ví dụ `ConnectionStrings__DefaultConnection`, `Jwt__SecretKey`, `App__ClientUrl`, `VnPay__*`, `MoMo__*`, `Cloudinary__*`, `DataProtection__KeysPath=C:\eduviet-data\keys`, `Storage__LocalRoot=C:\eduviet-data\storage`. Cấp quyền ghi cho identity của Application Pool vào `C:\eduviet-data` và `wwwroot\uploads`.
6. Gắn chứng chỉ HTTPS cho site (win-acme để lấy Let's Encrypt). Để `Https__Redirect=true`.

Phương án C — Azure

Thành phần	Dịch vụ	Ghi chú
API	App Service Linux (.NET 10)	Đặt cấu hình ở *Environment variables*; khóa bí mật để trong Key Vault
Frontend	Static Web Apps	Build `npm run build`, thư mục `dist`; khai báo route `/api/*` tới App Service (linked backend)
Database	Azure SQL Database (gói S0 trở lên)	Bật *Allow Azure services*; chạy migration bundle trong pipeline
Tệp	Cloudinary	Không lưu tệp trên đĩa App Service
Data Protection	Blob Storage	Hoặc `DataProtection__KeysPath=/home/keys` (thư mục `/home` của App Service là bền vững)

App Service Linux chưa có sẵn font tiếng Việt. Muốn PDF chứng chỉ hiển thị đúng dấu, triển khai API dạng container (dùng `src/backend/Dockerfile`, đã cài font), hoặc đặt tệp `.ttf` vào thư mục `Fonts/`.

Checklist trước khi mở cho người dùng

Bảo mật - [ ] `ASPNETCORE_ENVIRONMENT=Production` (Swagger tự tắt) - [ ] `Jwt:SecretKey` ngẫu nhiên ≥ 32 ký tự; không có bí mật nào trong `appsettings.json` hay git - [ ] `Payments:TestGateway:Enabled=false`. **Bắt buộc**, nếu không khách có thể "thanh toán" mà không trả tiền - [ ] HTTPS bắt buộc; `App:ClientUrl` và `Payments:ReturnUrl` dùng `https://` và tên miền thật - [ ] Chỉ mở cổng 80/443; SQL Server và API không mở ra Internet (`ForwardedHeaders` đang tin mọi proxy, nên API chỉ được đứng sau Nginx) - [ ] Mật khẩu SA mạnh; tốt nhất tạo user SQL riêng chỉ có quyền trên `OnlineLearningDb` - [ ] Không bật `Seed:RunOnStartup` (seed này tạo tài khoản demo)

Thanh toán - [ ] VNPay/MoMo đã chuyển sang khóa và URL **production** - [ ] Đã khai báo URL IPN `https://<tên miền>/api/payments/vnpay/ipn` trong trang merchant VNPay; MoMo dùng `…/momo/ipn` - [ ] Đã thử một giao dịch thật số tiền nhỏ và đối chiếu trang Admin → Giao dịch

Cơ sở dữ liệu - [ ] Migration `InstructorProfileAndMessaging` (hồ sơ giảng viên, tin nhắn) được áp dụng tự động khi `Database__MigrateOnStartup=true`; DBA chạy tay thì dùng `setup/database/migration-InstructorProfileAndMessaging.sql` (idempotent)

- [ ] Migration `RewardPoints` (điểm thưởng) được áp dụng tự động; chạy tay thì dùng `setup/database/migration-RewardPoints.sql`. Rà lại số điểm từng nhiệm vụ tại Quản trị › Điểm thưởng trước khi mở cho học viên

Nội dung & SEO - [x] Điều khoản hoàn tiền đã xác nhận (06/11/2026): yêu cầu trong 7 ngày, đã học tối đa 20%, chưa cấp chứng chỉ; phản hồi trong 7 ngày làm việc - [ ] Thay email, điện thoại, địa chỉ mẫu bằng thông tin thật trong `src/frontend/online-learning-client/src/config/site.ts` (mục "CẦN THAY") - [ ] Nhờ người có chuyên môn pháp lý rà soát các trang `/chinh-sach/*` - [ ] `PUBLIC_URL` đúng tên miền thật: docker-compose truyền vào `VITE_SITE_URL` khi build để thẻ Open Graph/canonical dùng URL tuyệt đối - [ ] Sửa dòng `Sitemap:` trong `public/robots.txt` thành URL đầy đủ, rồi khai báo `https://<tên miền>/sitemap.xml` trong Google Search Console - [ ] Thêm link mạng xã hội thật vào `site.social` (để trống thì footer không hiện)

Vận hành - [ ] Đã cấu hình SMTP để email đặt lại mật khẩu gửi được - [ ] Đã cấu hình Cloudinary (hoặc volume tệp được sao lưu) - [ ] Khóa Data Protection lưu bền vững (`DataProtection:KeysPath` trỏ vào volume) - [ ] Có lịch sao lưu DB hằng ngày và đã thử khôi phục - [ ] Giám sát `/api/health` (UptimeRobot, Azure Monitor…); log được thu thập (`docker compose logs`, hoặc thêm Serilog sink) - [ ] Có font tiếng Việt cho PDF (đã có sẵn trong `src/backend/Dockerfile`) - [ ] Kiểm tra giấy phép QuestPDF: bản Community chỉ miễn phí cho tổ chức có doanh thu dưới 1 triệu USD/năm

12 — Báo cáo kiểm thử (Giai đoạn 7)

Tầng	Công cụ	Số kịch bản	Kết quả
Backend tích hợp	xUnit + WebApplicationFactory + SQLite in-memory	43	**43/43 đạt**
End-to-end	Playwright (Chrome) + API demo + Vite	25 (18 desktop, 7 điện thoại)	**25/25 đạt**
Giao diện	taste-skill `inspect.mjs` (1440 / 768 / 390 px)	Trang chủ, chi tiết khóa, xác minh	Trang chủ 0 FAIL; các trang khác đã sửa lỗi tương phản/bố cục
Thủ công trên trình duyệt	Claude Browser	Mọi luồng chính của 3 vai trò	Đạt

1. Backend (`src/backend/tests`)

Nhóm	Kịch bản chính
Danh mục & khóa học	Trang chủ; sitemap.xml chỉ chứa khóa đã xuất bản; tìm kiếm/lọc/sắp xếp; ẩn khóa Pending; chỉ lộ video bài học thử
Tài khoản	Đăng ký, refresh token xoay vòng, phát hiện dùng lại token cũ → thu hồi mọi phiên; đăng xuất; sai mật khẩu; validation; đổi mật khẩu; phân quyền 401/403
Mua hàng	Giỏ hàng; báo giá; chống sửa giá; mã giảm giá (sai, tối thiểu, 100%); đơn 0đ; chặn mua trùng; hủy đơn; đánh giá một lần
Giảng viên/Admin	Tạo khóa → gửi duyệt → từ chối → duyệt; khóa chỉnh sửa khi chờ duyệt; giảng viên không thấy khóa của nhau; vai trò; khóa tài khoản; mã giảm giá; danh mục
Học tập & quiz	Nội dung chặn khi chưa mua; tiến độ; tiếp tục học; giới hạn lượt; nộp lặp; hoàn thành khóa; người khác không nộp hộ được
Thanh toán	Kênh test qua IPN có chữ ký + chống phát lại; VNPay sai chữ ký (97) / sai số tiền (04) / không tồn tại (01) / hợp lệ (00) / lặp (02) / thất bại; trang return không cấp quyền; MoMo đúng/sai chữ ký; Admin xem giao dịch
Tệp	Ảnh hợp lệ / giả định dạng / đuôi cấm; học viên không tải video được; video riêng tư chỉ phát qua URL có chữ ký
Giảng viên & tin nhắn	Hồ sơ công khai (kinh nghiệm, xác minh, thống kê); giảng viên sửa hồ sơ + validation (URL https, năm, gộp chuyên môn trùng); học viên không gọi được API hồ sơ; nhắn tin: không tự nhắn, chỉ nhắn giảng

Nhóm	Kịch bản chính
	viên, chưa đọc/đã đọc, thông báo, người ngoài không đọc được, cùng một cuộc trao đổi; Admin chỉ xác minh được giảng viên
Điểm thưởng	Xem `14-diem-thuong.md` mục 4 (7 kịch bản: làm tròn, IPN lặp, giới thiệu, hoàn tiền, điểm danh đồng thời + chuỗi, chia sẻ chống gian lận, đổi điểm, quyền Admin, CSV)
Chứng chỉ	Cấp đúng một lần; PDF hợp lệ; người khác không tải được; xác minh công khai; thu hồi/khôi phục; cấp bù

2. End-to-end (`src/frontend/online-learning-client/e2e`)

Tệp	Kịch bản
`public.spec.ts`	Trang chủ: đủ các section, tab lĩnh vực đổi nội dung, menu "Khóa học" trên header lọc đúng, ô xác minh chứng chỉ; trang Giới thiệu/Liên hệ/Chính sách, canonical, JSON-LD Course, robots.txt, sitemap.xml; mở ô tìm kiếm → tìm kiếm → chi tiết; lọc + sắp xếp lưu trên URL; mua khi chưa đăng nhập → chuyển tới đăng nhập; xác minh mã không tồn tại; `/quan-tri` yêu cầu đăng nhập
`student.spec.ts`	Đăng ký → thêm giỏ → mã sai/đúng → kênh test (có thông báo "chưa thu tiền thật") → kết quả thành công → vào học (có video). Đăng ký khóa miễn phí → học hết bài → làm quiz đạt → nhận mã chứng chỉ → tải PDF → chuông thông báo có "Bạn đã nhận chứng chỉ" → người lạ xác minh hợp lệ. Dashboard học viên mẫu → "Học tiếp"
`staff.spec.ts`	Giảng viên: biểu đồ tổng quan, tạo khóa, chương, bài, bài kiểm tra, gửi duyệt bị chặn vì thiếu thông tin. Admin: duyệt khóa chờ duyệt → khóa xuất hiện công khai; trang giao dịch. Học viên bị chặn khỏi `/quan-tri` và `/giang-day`
`instructor.spec.ts`	Hồ sơ giảng viên có huy hiệu xác minh, kinh nghiệm, chứng nhận, JSON-LD Person; khách bấm nhắn tin → đăng nhập; học viên hỏi về khóa học → giảng viên nhận thông báo, trả lời → học viên thấy; giảng viên sửa hồ sơ (lỗi báo đúng ô, trang công khai cập nhật); Admin xác minh → huy hiệu hiện trên trang khóa học
`rewards.spec.ts`	Học viên điểm danh, nhiệm vụ, lịch sử, chia sẻ tạo liên kết riêng, mã giới thiệu được nhớ khi đăng ký; Admin xem tổng quan, sửa nhiệm vụ, điều chỉnh điểm có lý do, lịch sử
`mobile.spec.ts`	Không tràn ngang trên 6 trang; menu điện thoại; bộ lọc dạng sheet

Mỗi lần chạy E2E dùng một DB SQLite mới với dữ liệu mẫu. API chạy trên cổng 5081, Vite trên cổng 5174, nên không ảnh hưởng server đang dùng để phát triển.

3. Lỗi phát hiện nhờ kiểm thử (đã sửa)

Giai đoạn	Lỗi	Phát hiện bởi
3	Giờ hiển thị lệch 7 tiếng (DateTime thiếu "Z")	Chạy thử trên trình duyệt
3	Trang thanh toán tự quay về giỏ hàng sau khi đặt; thông báo mã giảm giá sai bị xóa ngay; tiền định dạng "249,000đ"	Chạy thử trên trình duyệt
4	Nộp bài xong không hiện kết quả; thẻ `<a>` lồng nhau; số liệu tràn ô	Chạy thử trên trình duyệt
5	VNPay yêu cầu trường `RspCode` nhưng API trả `rspCode`	Test tích hợp
5	SMTP mặc định trỏ `localhost` làm "quên mật khẩu" lỗi 500	Rà soát cấu hình
6	QuestPDF không thấy font hệ thống → PDF lỗi 500	Test tích hợp
7	Rate limit đăng nhập chặn kiểm thử tự động → thêm `RateLimiting:Enabled` (chỉ tắt khi chạy E2E)	E2E

Các lỗi E2E ở lần chạy đầu đều nằm trong kịch bản test (bộ chọn trùng phần tử, đếm trước khi dữ liệu tải xong), không phải lỗi ứng dụng.

4. Chưa kiểm thử được

- Chạy trên **SQL Server thật**: máy phát triển không có SQL Server. Migration đã được sinh và CI kiểm tra model không lệch migration, nhưng chưa áp dụng vào SQL Server.
- **VNPay/MoMo sandbox thật**: cần khóa merchant và URL công khai (ngrok). Thuật toán ký đã được test với khóa giả theo đặc tả.
- **Cloudinary thật**: cần khóa. Đã test đầy đủ với lưu trữ cục bộ cùng giao diện `IFileStorage`.
- **Docker Compose**: chưa build được vì máy không có Docker.
- **CI GitHub Actions**: đã viết workflow nhưng chưa chạy, vì thư mục chưa phải repo git và chưa có remote.

13 — Design system giao diện

Phong cách: "technology platform" sáng, thoáng (tham khảo ngôn ngữ thiết kế của các trang giới thiệu nền tảng công nghệ như digibird.co). Thương hiệu EduViet được giữ nguyên: logo, màu xanh #005CF8, cam #EF8000, nội dung và dữ liệu thật từ API.

Mã nguồn: token và utility nằm trong `src/frontend/online-learning-client/src/index.css`, component dùng chung nằm trong `src/components/ui/index.tsx`.

Token

Nhóm	Giá trị
Màu chính	`brand-50 … brand-900`, chính là `brand-600` #005CF8
Màu nhấn	`accent-*` (cam, dùng cho giá và đánh giá); `mint-*` (trang trí: gạch chân từ khóa, khối nền, gạch dưới menu đang chọn)
Nền	`surface` #fff, `surface-2` #f6f8fc (dải tiêu đề, section xen kẽ), `line` #e4e9f1
Chữ	Tiêu đề **Lexend** (h1–h3, `.font-display`), thân bài **Be Vietnam Pro**. Cả hai hỗ trợ tiếng Việt
Cỡ chữ	`text-display` (hero, 36–58px) · `text-title` (h1 trang con, h2 section, 27–38px) · `text-heading` (h3 thẻ, 20px)
Bo góc	`--radius-card` 16px · `--radius-control` 10px (nút, ô nhập)
Đổ bóng	`--shadow-soft` (thẻ khi tĩnh) · `--shadow-lift` (hover, vùng nổi) · `--shadow-brand` (hover nút chính)
Khoảng cách	Thang 4px của Tailwind; section dọc 80–96px (`py-20 md:py-24`), khoảng cách giữa các thẻ 24px
Breakpoint	sm 640 · md 768 (tablet) · lg 1024 (menu đầy đủ) · xl 1280

Utility

Utility	Dùng cho
`btn-primary` / `btn-outline`	Cặp CTA chính / phụ. Hover nhấc 1px và có bóng, active co 0.97, disabled mờ 50%
`btn-soft` / `btn-ghost` / `btn-accent` / `btn-light`	Hành động thứ cấp, nút trong thanh công cụ, nút cam, nút trên nền màu

Utility	Dùng cho
`card` + `card-hover`	Thẻ trắng có viền mảnh và bóng nhẹ, thẻ bấm được nhấc lên khi hover
`input`	Ô nhập: hover và focus có viền xanh và vòng sáng; có trạng thái `aria-invalid` và `disabled`
`chip`, `eyebrow`, `mark-mint`	Nhãn viên thuốc, nhãn nhỏ trên tiêu đề, gạch chân từ khóa
`float-slow`, `rise-in`, `[data-reveal]` + `useReveal`	Chuyển động nhẹ. Tất cả tắt khi người dùng bật "giảm chuyển động"

Component dùng chung

- `PageHeader`: dải tiêu đề trang con gồm đường dẫn, nhãn, h1, mô tả và hành động. Đang dùng ở các trang Khóa học, Giỏ hàng, Thanh toán, Lịch sử mua hàng.
- `SectionHeading`: tiêu đề section, căn trái kèm hành động hoặc căn giữa.
- `DecorBlobs`: khối tròn mờ trang trí nằm phía sau nội dung.
- `ResponsiveImg`: ảnh có `srcset` / `sizes` (Cloudinary dùng `f_auto,q_auto`; picsum đổi kích thước theo URL), mặc định tải lười.
- `CourseCard` / `CourseGrid`: thẻ khóa học dạng card, hiển thị lĩnh vực, thông số bài, thời lượng, học viên và giá.
- Header (`MainLayout`): menu có biểu tượng, menu thả xuống "Khóa học" lấy lĩnh vực từ API, ô tìm kiếm mở bằng biểu tượng kính lúp, có bóng khi cuộn, menu hamburger trên điện thoại. Footer: dải CTA và 4 cột liên kết.

14 — Điểm thưởng (Reward Points)

1. Quy tắc mặc định

Admin chỉnh được tại **Quản trị › Điểm thưởng › Nhiệm vụ & quy tắc**.

Nhiệm vụ (khóa)	Điểm	Điều kiện và chống gian lận
Mua khóa học (`purchase`)	10 điểm / 100.000đ	Chỉ cộng trong transaction xác nhận thanh toán từ **IPN đã kiểm tra chữ ký và số tiền** (`OrderFulfillmentService.MarkPaidAsync`). Trang redirect sau thanh toán không cộng điểm. Đơn 0đ không có điểm.
Hoàn thành khóa học (`course_completion`)	100	Do backend xác định từ tiến độ thật: 100% bài bắt buộc và đạt các bài kiểm tra bắt buộc, cùng điều kiện cấp chứng chỉ. Không có API nào để client tự xin điểm. Mỗi khóa chỉ một lần, kể cả khi ghi danh lại.
Điểm danh hằng ngày (`daily_checkin`)	5	Một lần mỗi ngày theo giờ Việt Nam (UTC+7). Có unique `(UserId, CheckInDate)`.
Điểm danh liên tục (`checkin_streak`)	30, ngưỡng 7 ngày	Cộng mỗi khi chuỗi đạt bội số của ngưỡng (7, 14, 21…). Bỏ lỡ một ngày, chuỗi bắt đầu lại từ 1.
Chia sẻ khóa học (`course_share`)	5	Chỉ cộng khi **người khác mở** liên kết chia sẻ, tức khác tài khoản và khác IP người tạo. Tối đa một lần mỗi ngày. Mỗi người xem tính một lần. Liên kết cũ hơn 30 ngày không còn được thưởng. Bấm nút chia sẻ không tự cộng điểm.
Giới thiệu bạn bè (`referral`)	50	Người được giới thiệu đăng ký bằng mã (`?ref=` hoặc mã đã lưu khi mở liên kết chia sẻ) và **thanh toán thành công đơn có phí đầu tiên**. Mỗi người chỉ được giới thiệu bởi một người. Tự giới thiệu bị bỏ qua.
Đổi điểm (`redeem_voucher`)	100 điểm = 10.000đ, tối thiểu 100	Tạo mã giảm giá cá nhân (`Coupon.RestrictedToUserId`), dùng một lần, hạn 90 ngày. Chỉ chủ sở hữu dùng được.

Làm tròn điểm mua hàng

`Số điểm = floor(Số tiền thanh toán hợp lệ × Điểm / Đơn vị tiền)`, tức **làm tròn xuống tới điểm nguyên**. Số tiền tính là tổng đã thanh toán sau mã giảm giá (`Order.TotalAmount`).

Ví dụ với 10 điểm/100.000đ:

Số tiền thanh toán	Điểm
390.000đ	39

Số tiền thanh toán	Điểm
249.000đ	24
9.999đ	0

Hoàn tiền

Admin chọn **Đơn hàng › Hoàn tiền** sau khi đã hoàn tiền cho khách qua cổng thanh toán. Hệ thống sẽ:

- Chuyển đơn sang `Refunded` và thu hồi quyền học các khóa trong đơn.
- Thu hồi điểm mua hàng của đơn.
- Thu hồi thưởng giới thiệu, nếu thưởng đó được trao nhờ đơn này.

Nếu học viên đã tiêu bớt điểm, hệ thống chỉ thu phần điểm còn lại, vì số dư không bao giờ âm. Đơn đã cấp chứng chỉ không hoàn tiền được, đúng theo chính sách hoàn tiền.

2. Thiết kế kỹ thuật

- **Sổ cái duy nhất:** mọi cộng/trừ đều đi qua `RewardService.ApplyAsync`, và luôn chạy trong transaction.
- Số dư cập nhật bằng **một câu** `UPDATE … SET Balance = Balance + x` **nguyên tử**, không đọc-sửa-ghi.
- Lệnh trừ có điều kiện `WHERE Balance >= x`, nên không bao giờ âm. Ngoài ra còn có check constraint `CK_UserPoints_Balance`.
- **Idempotency:** mỗi bút toán có `ReferenceKey` duy nhất theo người dùng, với unique index `(UserId, ReferenceKey)`. Ví dụ:
- `purchase:{orderId}`
- `checkin:2026-11-07`
- `share:2026-11-07` (bảo đảm mỗi ngày chỉ một lần thưởng chia sẻ)
- `course_completion:{courseId}`
- `referral:{userId}`
- `refund:{orderId}`
- **Đồng thời:** hai yêu cầu giống nhau gửi cùng lúc thì yêu cầu sau vi phạm unique index, transaction bị rollback và trả 409. Có test cho trường hợp điểm danh đồng thời.
- **Không tin client:** API không nhận số điểm từ client, trừ điều chỉnh thủ công của Admin. Admin phải có role và phải ghi lý do; lý do được lưu vào lịch sử và báo cho học viên.
- **Quyền:** `/api/rewards/*` yêu cầu JWT. `/api/admin/rewards/*` chỉ dành cho role Admin. Riêng `POST /api/rewards/shares/{token}/open` cho phép ẩn danh, luôn trả 204 và có giới hạn tần suất.
- **Quyền riêng tư:** không lưu IP thô. Người mở liên kết được nhận diện bằng SHA-256 của IP và User-Agent.

Bảng dữ liệu (migration `RewardPoints`)

Bảng	Nội dung	Ràng buộc chính
`UserPoints`	Số dư, tổng tích lũy, tổng đã dùng	Unique `UserId`; check `Balance >= 0`
`PointTransactions`	Lịch sử cộng/trừ (không sửa/xóa)	Unique `(UserId, ReferenceKey)`; index theo thời gian, quy tắc
`PointRules`	Cấu hình nhiệm vụ	Unique `Key`; check `Points >= 0`
`DailyCheckIns`	Lịch sử điểm danh, chuỗi	Unique `(UserId, CheckInDate)`
`CourseShares` / `CourseShareOpens`	Liên kết chia sẻ, lượt mở	Unique `Token`; unique `(CourseShareId, VisitorKey)`
`PointRedemptions`	Lịch sử đổi điểm	Unique `CouponId`; check `Points > 0`
`ReferralCodes` / `Referrals`	Mã giới thiệu, quan hệ giới thiệu	Unique `Code`, `UserId`; unique `ReferredUserId`

Các cột thêm vào bảng cũ:

- `Orders.RefundedAt`, `Orders.RefundReason`
- `Coupons.RestrictedToUserId`

API

Phương thức	Đường dẫn	Mô tả
GET	`/api/rewards/summary`	Số dư, điểm danh, nhiệm vụ, mã giới thiệu, cấu hình đổi điểm
GET	`/api/rewards/transactions`	Lịch sử điểm của tôi
POST	`/api/rewards/check-in`	Điểm danh
POST	`/api/rewards/shares`	Tạo liên kết chia sẻ `{ courseId, channel }`
POST	`/api/rewards/shares/{token}/open`	Ghi nhận lượt mở (ẩn danh)
POST	`/api/rewards/redeem`	Đổi điểm `{ points }`
GET	`/api/rewards/redemptions`	Mã đã đổi
GET	`/api/admin/rewards/overview` · `balances` · `transactions` · `transactions/export`	Thống kê, điểm học viên, lịch sử, xuất CSV
GET/POST/PUT/DELETE	`/api/admin/rewards/rules`	Quản lý nhiệm vụ. Nhiệm vụ hệ thống chỉ sửa và bật/tắt, không xóa

Phương thức	Đường dẫn	Mô tả
POST	`/api/admin/rewards/adjustments`	Điều chỉnh thủ công `{ userId, points, reason }`
POST	`/api/admin/orders/{id}/refund`	Xác nhận hoàn tiền `{ reason }`

3. Chạy migration, API, frontend

SQL Server. Migration tự áp dụng khi khởi động nếu `Database:MigrateOnStartup=true`, ví dụ khi chạy Docker. Muốn chạy tay:

```
cd src\backend
dotnet ef database update -p src\OnlineLearning.Infrastructure -s src\OnlineLearning.API
```

DBA có thể chạy script idempotent `setup/database/migration-RewardPoints.sql`. Các quy tắc mặc định được seed tự động khi API khởi động; seed chỉ thêm quy tắc còn thiếu, không ghi đè cấu hình Admin đã chỉnh.

Chế độ demo SQLite. Chế độ này tạo DB bằng `EnsureCreated` nên không tự nâng cấp schema. Dừng API, đổi tên hoặc xóa `src/backend/src/OnlineLearning.API/eduviet-demo.db`, rồi chạy:

```
cd src\backend\src\OnlineLearning.API
dotnet run --launch-profile demo-sqlite
```

Frontend:

```
cd src\frontend\online-learning-client
npm run dev
```

Các trang:

- Học viên: `/hoc-vien/diem-thuong`
- Admin: `/quan-tri/diem-thuong`
- Nút "Chia sẻ khóa học" nằm trên trang chi tiết khóa học.

> Khi chạy thử trên một máy, mở liên kết chia sẻ của chính mình (cùng IP) **không** được cộng điểm. Đây là cơ chế chống gian lận. Muốn thấy điểm chia sẻ, hãy mở liên kết từ thiết bị hoặc mạng khác.

4. Kiểm thử

- **Backend,** `RewardTests`**:** làm tròn điểm; IPN lặp không cộng trùng; thưởng giới thiệu; hoàn tiền thu hồi cả điểm mua hàng lẫn thưởng giới thiệu; điểm danh một lần mỗi ngày, kể cả hai yêu cầu đồng thời; chuỗi 7 ngày và reset sau khi bỏ lỡ; chia sẻ chỉ thưởng khi người khác mở và tối đa một lần mỗi ngày; hoàn thành khóa chỉ thưởng một lần; đổi điểm tạo mã cá nhân và không âm điểm; điều chỉnh thủ công bắt buộc lý do; quyền Admin; xuất CSV.
- **E2E,** `rewards.spec.ts`**:** học viên điểm danh, xem nhiệm vụ và lịch sử, chia sẻ tạo liên kết riêng, khách mở liên kết và mã giới thiệu được nhớ khi đăng ký; Admin xem tổng quan, sửa nhiệm vụ, điều chỉnh điểm có lý do, xem lịch sử, và học viên thấy được điều chỉnh.